

INTERNACIONAL ESTÁNDAR

ISO/IEC 27005

Cuarta edición
2022-10

Seguridad de la información, ciberseguridad y protección de la privacidad: Orientación sobre la gestión de riesgos de seguridad de la información

Seguridad de la información, ciberseguridad y protección de la vida
privada — Preconizaciones para la gestión de riesgos relacionados con la
seguridad de la información



Número de referencia
ISO/IEC 27005:2022(E)

© ISO/IEC 2022

ISO/IEC 27005:2022(E)



DOCUMENTO PROTEGIDO POR DERECHOS DE AUTOR

© ISO/IEC 2022

Todos los derechos reservados. Salvo que se especifique lo contrario o se requiera en el contexto de su implementación, ninguna parte de esta publicación podrá reproducirse ni utilizarse de ninguna forma ni por ningún medio, ya sea electrónico o mecánico, incluyendo fotocopias, ni publicarse en internet o intranet, sin autorización previa por escrito. La autorización puede solicitarse a ISO en la dirección que figura a continuación o al organismo miembro de ISO en el país del solicitante.

Oficina de derechos de
autor ISO CP 401 • Ch. de Blandonnet
8 CH-1214 Vernier, Ginebra
Teléfono: +41 22 749 01 11

Correo electrónico:
copyright@iso.org Sitio web: www.iso.org

Publicado en Suiza

Contenido

Página

Prólogo.....	v
Introducción.....	vi
1 Alcance.....	1
2 Referencias normativas.....	1
3 Términos y definiciones.....	1
3.1 Términos relacionados con el riesgo de seguridad de la información.....	5
1 3.2 Términos relacionados con la gestión de riesgos de seguridad de la información.....	5
4 Estructura de este documento.....	7
5 Gestión de riesgos de seguridad de la información.....	7 5.1
Proceso de gestión de riesgos de seguridad de la información.....	7 5.2 Ciclos
de gestión de riesgos de seguridad de la información	9
6 Establecimiento del contexto.....	9
6.1 Consideraciones organizacionales	9
6.2 Identificación de los requisitos básicos de las partes interesadas	10 6.3
Aplicación de la evaluación de riesgos.....	10 6.3
10 6.4 Establecimiento y mantenimiento de los criterios de riesgo de seguridad de la información	11 6.4.1
General.....	11
6.4.2 Criterios de aceptación de riesgos	11
6.4.3 Criterios para realizar evaluaciones de riesgos de seguridad de la información	13 6.5 Elección
de un método apropiado	15 7 Proceso de
evaluación de riesgos de seguridad de la información	16 7.1
General.....	16
7.2 Identificación de riesgos de seguridad de la información	17
17 7.2.1 Identificación y descripción de riesgos de seguridad de la información.....	17
7.2.2 Identificación de los propietarios de los riesgos.....	17
18 7.3 Análisis de riesgos de seguridad de la información	19
19 7.3.1 General.....	19
19 7.3.2 Evaluación de consecuencias potenciales	19
19 7.3.3 Evaluación de probabilidad.....	19
20 7.3.4 Determinación de los niveles de riesgo	20
22 7.4 Evaluación de los riesgos de seguridad de la información	22
22 7.4.1 Comparación de los resultados del análisis de riesgos con los criterios de riesgo.....	22
22 7.4.2 Priorizar los riesgos analizados para el tratamiento de riesgos.....	23
8 Proceso de tratamiento de riesgos de seguridad de la información.....	23 8.1
General.....	23
8.2 Seleccionar opciones adecuadas para el tratamiento de riesgos de seguridad de la información	23 8.3
Determinar todos los controles necesarios para implementar la seguridad de la información.	
Opciones de tratamiento de riesgos	27
8.4 Comparación de los controles determinados con los de la norma ISO/IEC 27001:2022, Anexo A.....	27 8.5 Elaboración de
una declaración de aplicabilidad.....	27 8.6 Plan de tratamiento
de riesgos de seguridad de la información	28 8.6.1 Formulación del plan de
tratamiento de riesgos.....	28 8.6.2 Aprobación por parte de los
propietarios de los riesgos.....	29 8.6.3 Aceptación de los riesgos
residuales de seguridad de la información	30 9
Operación.....	31
9.1 Realización del proceso de evaluación de riesgos de seguridad de la información	31 9.2
Realización del proceso de tratamiento de riesgos de seguridad de la información.....	31 10
Aprovechamiento de los SGSI relacionados Procesos.....	
10.1 Contexto de la organización.....	32
10.2 Liderazgo y compromiso.....	32

ISO/IEC 27005:2022(E)

10.3 Comunicación y consulta.....33

10.4 Información documentada35

 10.4.1 General.....35

 10.4.2 Información documentada sobre los procesos.....35 10.4.3

 Información documentada sobre los resultados.....35 10.5

Seguimiento y revisión.....36 10.5.1

 General.....36

 10.5.2 Seguimiento y revisión de los factores que influyen en los riesgos37 10.6

Revisión por la dirección.....38 10.7

Medidas correctivas acción.....38

10.8 Mejora continua39

Anexo A (informativo) Ejemplos de técnicas de apoyo al proceso de evaluación de riesgos41

Bibliografía.....62

Prefacio

La ISO (Organización Internacional de Normalización) y la IEC (Comisión Electrotécnica Internacional) conforman el sistema especializado de normalización mundial. Los organismos nacionales miembros de la ISO o la IEC participan en el desarrollo de normas internacionales a través de comités técnicos establecidos por la respectiva organización para abordar áreas específicas de actividad técnica. Los comités técnicos de la ISO y la IEC colaboran en áreas de interés mutuo. Otras organizaciones internacionales, gubernamentales y no gubernamentales, en colaboración con la ISO y la IEC, también participan en la labor.

Los procedimientos empleados para desarrollar este documento y los destinados a su posterior mantenimiento se describen en las Directivas ISO/IEC, Parte 1. En particular, deben tenerse en cuenta los diferentes criterios de aprobación necesarios para los distintos tipos de documentos. Este documento se redactó de acuerdo con las normas editoriales de las Directivas ISO/IEC, Parte 2 (véase www.iso.org/directives), o www.iec.ch/members_experts/refdocs).

Se advierte la posibilidad de que algunos elementos de este documento estén sujetos a derechos de patente. ISO e IEC no se responsabilizan de la identificación de ninguno o todos estos derechos de patente. Los detalles de cualquier derecho de patente identificado durante el desarrollo del documento se encontrarán en la Introducción o en la lista ISO de declaraciones de patentes recibidas (véase www.iso.org/patents), o la lista IEC de declaraciones de patentes recibidas (véase <https://patents.iec.ch>).

Cualquier nombre comercial utilizado en este documento es información proporcionada para conveniencia de los usuarios y no constituye un respaldo.

Para una explicación del carácter voluntario de las normas, el significado de los términos y expresiones específicos de ISO relacionados con la evaluación de la conformidad, así como información sobre la adhesión de ISO a los principios de la Organización Mundial del Comercio (OMC) en el ámbito de los Obstáculos Técnicos al Comercio (OTC), consulte www.iso.org/iso/foreword.html. En el caso de la IEC, consulte www.iec.ch/understanding-standards.

Este documento fue preparado por el Comité Técnico Conjunto ISO/IEC JTC 1, Tecnología de la información, Subcomité SC 27, Seguridad de la información, ciberseguridad y protección de la privacidad.

Esta cuarta edición anula y reemplaza la tercera edición (ISO/IEC 27005:2018), que ha sido revisada técnicamente.

Los principales cambios son los siguientes:

- todo el texto de orientación se ha alineado con las normas ISO/IEC 27001:2022 e ISO 31000:2018;
- la terminología se ha alineado con la terminología de la norma ISO 31000:2018;
- la estructura de las cláusulas se ha ajustado al diseño de la norma ISO/IEC 27001:2022;
- se han introducido conceptos de escenarios de riesgo;
- el enfoque basado en eventos se contrasta con el enfoque basado en activos para la identificación de riesgos;
- Se ha revisado el contenido de los anexos y se ha reestructurado en un único anexo.

Cualquier comentario o pregunta sobre este documento debe dirigirse al organismo nacional de normalización del usuario. Puede consultar la lista completa de estos organismos en www.iso.org/members.html, y www.iec.ch/national-committees.

ISO/IEC 27005:2022(E)

Introducción

Este documento proporciona orientación sobre:

- implementación de los requisitos de riesgo de seguridad de la información especificados en la norma ISO/IEC 27001;
- referencias esenciales dentro de las normas desarrolladas por ISO/IEC JTC 1/SC 27 para respaldar la información actividades de gestión de riesgos de seguridad;
- acciones que aborden los riesgos relacionados con la seguridad de la información (véase ISO/IEC 27001:2022, 6.1 y Cláusula 8);
- implementación de la guía de gestión de riesgos de la norma ISO 31000 en el contexto de la seguridad de la información.

Este documento contiene orientación detallada sobre la gestión de riesgos y complementa la orientación de la norma ISO/IEC 27003.

Este documento está destinado a ser utilizado por:

- organizaciones que pretenden establecer e implementar un sistema de gestión de seguridad de la información (SGSI) de acuerdo con la norma ISO/IEC 27001;
- personas que realizan o están involucradas en la gestión de riesgos de seguridad de la información (por ejemplo, SGSI) profesionales, propietarios de riesgos y otras partes interesadas);
- organizaciones que desean mejorar su proceso de gestión de riesgos de seguridad de la información.

Seguridad de la información, ciberseguridad y protección de la privacidad:

Orientación sobre la gestión de riesgos de seguridad de la información

1 Alcance

Este documento proporciona orientación para ayudar a las organizaciones a:

- cumplir los requisitos de la norma ISO/IEC 27001 relativos a las acciones para abordar los riesgos de seguridad de la información;
- realizar actividades de gestión de riesgos de seguridad de la información, específicamente gestión de riesgos de seguridad de la información evaluación y tratamiento.

Este documento es aplicable a todas las organizaciones, independientemente de su tipo, tamaño o sector.

2 Referencias normativas

Los siguientes documentos se mencionan en el texto de tal manera que parte o la totalidad de su contenido constituye requisitos de este documento. Para las referencias fechadas, solo se aplica la edición citada. Para las referencias sin fecha, se aplica la última edición del documento referenciado (incluidas las modificaciones).

ISO/IEC 27000, Tecnología de la información — Técnicas de seguridad — Sistemas de gestión de la seguridad de la información — Descripción general y vocabulario

3 Términos y definiciones

Para los fines de este documento, se aplican los términos y definiciones dados en ISO/IEC 27000 y los siguientes.

ISO e IEC mantienen bases de datos terminológicas para su uso en la estandarización en las siguientes direcciones:

- Plataforma de navegación en línea ISO: disponible en <https://www.iso.org/obp>
- IEC Electropedia: disponible en <https://www.electropedia.org/>

3.1 Términos relacionados con el riesgo de seguridad de la información

3.1.1

contexto externo

entorno externo en el que la organización busca alcanzar sus objetivos

Nota 1 a la entrada: El contexto externo puede incluir lo siguiente:

- el entorno social, cultural, político, jurídico, reglamentario, financiero, tecnológico, económico y geológico, ya sea internacional, nacional, regional o local;
- los factores y tendencias clave que afectan los objetivos de la organización;
- las relaciones, percepciones, valores, necesidades y expectativas de las partes interesadas externas;
- relaciones y compromisos contractuales;
- la complejidad de las redes y las dependencias.

[FUENTE: Guía ISO 73:2009, 3.3.1.1, modificada — Se ha modificado la Nota 1 de la entrada.]

ISO/IEC 27005:2022(E)

3.1.2

contexto interno

entorno interno en el que la organización busca alcanzar sus objetivos

Nota 1 a la entrada: El contexto interno puede incluir:

- visión, misión y valores;
- gobernanza, estructura organizacional, roles y responsabilidades;
- estrategia, objetivos y políticas;
- la cultura de la organización;
- normas, directrices y modelos adoptados por la organización;
- capacidades, entendidas en términos de recursos y conocimientos (por ejemplo, capital, tiempo, personas, procesos, sistemas) y tecnologías);
- datos, sistemas de información y flujos de información;
- las relaciones con las partes interesadas internas, teniendo en cuenta sus percepciones y valores;
- relaciones y compromisos contractuales;
- interdependencias e interconexiones internas.

[FUENTE: Guía ISO 73:2009, 3.3.1.2, modificada — Se ha modificado la Nota 1 de la entrada.]

3.1.3

Efecto

del riesgo de la incertidumbre sobre los objetivos

Nota 1 a la entrada: Un efecto es una desviación de lo esperado, positiva o negativa.

Nota 2 a la entrada: Los objetivos pueden tener diferentes aspectos y categorías, y pueden aplicarse en diferentes niveles.

Nota 3 a la entrada: La incertidumbre es el estado, incluso parcial, de deficiencia de información relacionada con la comprensión o el conocimiento de un evento [\(3.1.11\)](#), su consecuencia [\(3.1.14\)](#) o su probabilidad [\(3.1.13\)](#).

Nota 4 a la entrada: El riesgo suele expresarse en términos de fuentes de riesgo [\(3.1.6\)](#), [eventos](#) potenciales, sus consecuencias y su probabilidad.

Nota 5 a la entrada: En el contexto de los sistemas de gestión de la seguridad de la información, los riesgos de seguridad de la información pueden expresarse como el efecto de la incertidumbre sobre los objetivos de seguridad de la información.

Nota 6 a la entrada: Los riesgos de seguridad de la información suelen estar asociados a un efecto negativo de la incertidumbre sobre los objetivos de seguridad de la información.

Nota 7 a la entrada: Los riesgos de seguridad de la información pueden estar asociados con la posibilidad de que las [amenazas](#) [\(3.1.9\)](#) exploten las [vulnerabilidades](#) [\(3.1.10\)](#) de un activo de información o grupo de activos de información y, por lo tanto, causen daño a una organización.

[FUENTE: ISO 31000:2018, 3.1, modificada — la frase: “Puede ser positiva, negativa o ambas, y puede abordar, crear o dar lugar a oportunidades y amenazas” ha sido sustituida por “positiva o negativa” en la Nota 1 de la entrada; la Nota 3 original de la entrada ha sido renumerada como Nota 4 de la entrada; y se han añadido las Notas 3, 5, 6 y 7 de la entrada.]

3.1.4

escenario de

riesgo secuencia o combinación de eventos [\(3.1.11\)](#) que conducen desde la causa inicial hasta la consecuencia no deseada [\(3.1.14\)](#)

[FUENTE: ISO 17666:2016, 3.1.13, modificada — Se ha eliminado la Nota 1 de la entrada.]

3.1.5

propietario del

riesgo persona o entidad con la responsabilidad y autoridad para gestionar un riesgo (3.1.3)

[FUENTE: Guía ISO 73:2009, 3.5.1.5]

3.1.6

elemento fuente

de riesgo que solo o en combinación tiene el potencial de generar riesgo (3.1.3)

Nota 1 a la entrada: Una fuente de riesgo puede ser uno de estos tres tipos:

- humano;

— ambiental;

— técnico.

Nota 2 a la entrada: Un tipo de fuente de riesgo humano puede ser intencional o no intencional.

[FUENTE: ISO 31000:2018, 3.4, modificada — Se han añadido las notas 1 y 2 a la entrada.]

3.1.7

criterios de riesgo

términos de referencia con respecto a los cuales se evalúa la importancia de un riesgo (3.1.3)

Nota 1 a la entrada: Los criterios de riesgo se basan en los objetivos organizacionales y en el contexto externo (3.1.1) e interno (3.1.2).

Nota 2 a la entrada: Los criterios de riesgo pueden derivarse de normas, leyes, políticas y otros requisitos.

[FUENTE: Guía ISO 73:2009, 3.3.1.3]

3.1.8

apetito de riesgo

cantidad y tipo de riesgo (3.1.3) que una organización está dispuesta a asumir o retener

[FUENTE: Guía ISO 73:2009, 3.7.1.2]

3.1.9

amenaza

causa potencial de un incidente de seguridad de la información (3.1.12) que puede provocar daños a un sistema o perjuicios a una organización

3.1.10

vulnerabilidad

debilidad de un activo o control (3.1.16) que puede ser explotada para que ocurra un evento (3.1.11) con una consecuencia negativa (3.1.14)

3.1.11

evento

ocurrencia o cambio de un conjunto particular de circunstancias

Nota 1 a la entrada: Un evento puede tener una o más ocurrencias, y puede tener varias causas y varias consecuencias (3.1.14).

Nota 2 a la entrada: Un evento también puede ser algo que se espera y no sucede, o algo que no se espera y sí sucede.

[FUENTE: ISO 31000:2018, 3.5, modificada — Se ha eliminado la Nota 3 de la entrada.]

ISO/IEC 27005:2022(E)

3.1.12

incidente de seguridad de la información:

un solo evento o una serie de eventos de seguridad de la información no deseados o inesperados que tienen una probabilidad significativa de comprometer las operaciones comerciales y amenazar la seguridad de la información.

3.1.13

probabilidad

posibilidad de que algo suceda

Nota 1 a la entrada: En la terminología de gestión de riesgos, la palabra "probabilidad" se utiliza para referirse a la posibilidad de que algo suceda, ya sea definida, medida o determinada de manera objetiva o subjetiva, cualitativa o cuantitativa, y descrita utilizando términos generales o matemáticamente (como una probabilidad o una frecuencia durante un período de tiempo determinado).

Nota 2 a la entrada: El término inglés «likelihood» no tiene un equivalente directo en algunos idiomas; en su lugar, se suele utilizar el equivalente del término «probability». Sin embargo, en inglés, «probability» suele interpretarse de forma restringida como un término matemático. Por lo tanto, en la terminología de gestión de riesgos, «likelihood» se utiliza con la intención de que tenga la misma interpretación amplia que el término «probability» en muchos otros idiomas.

[FUENTE: ISO 31000:2018, 3.7]

3.1.14

consecuencia

resultado de un evento [\(3.1.11\)](#) que afecta a los objetivos

Nota 1 a la entrada: Una consecuencia puede ser cierta o incierta y puede tener efectos directos o indirectos, positivos o negativos, sobre los objetivos.

Nota 2 a la entrada: Las consecuencias pueden expresarse cualitativa o cuantitativamente.

Nota 3 a la entrada: Cualquier consecuencia puede escalar mediante efectos en cascada y acumulativos.

[FUENTE: ISO 31000:2018, 3.6]

3.1.15

nivel de riesgo

importancia de un riesgo [\(3.1.3\)](#), expresada en términos de la combinación de consecuencias [\(3.1.14\)](#) y su probabilidad [\(3.1.13\)](#)

[FUENTE: Guía ISO 73:2009, 3.6.1.8, modificada — la frase: "magnitud de un riesgo o combinación de riesgos" ha sido reemplazada por "importancia de un riesgo".]

3.1.16

medida

de control que mantiene y/o modifica el riesgo [\(3.1.3\)](#)

Nota 1 a la entrada: Los controles incluyen, pero no se limitan a, cualquier proceso, política, dispositivo, práctica u otras condiciones y/o acciones que mantengan y/o modifiquen el riesgo.

Nota 2 a la entrada: Es posible que los controles no siempre ejerzan el efecto modificador previsto o supuesto.

[FUENTE: ISO 31000:2018, 3.8]

3.1.17

riesgo residual

riesgo [\(3.1.3\)](#) restante después del tratamiento del riesgo [\(3.2.7\)](#)

Nota 1 a la entrada: El riesgo residual puede contener un riesgo no identificado.

Nota 2 a la entrada: Los riesgos residuales también pueden contener riesgo retenido.

[FUENTE: Guía ISO 73:2009, 3.8.1.6, modificada — Se ha modificado la Nota 2 de la entrada.]

3.2 Términos relacionados con la gestión de riesgos de seguridad de la información

3.2.1

proceso de gestión de riesgos

aplicación sistemática de políticas, procedimientos y prácticas de gestión a las actividades de comunicación, consulta, establecimiento del contexto e identificación, análisis, evaluación, tratamiento, seguimiento y revisión del riesgo (3.1.3)

[FUENTE: Guía ISO 73:2009, 3.1]

3.2.2

comunicación y consulta de riesgos

conjunto de procesos continuos e iterativos que una organización lleva a cabo para proporcionar, compartir u obtener información y para entablar un diálogo con las partes interesadas respecto a la gestión del riesgo (3.1.3)

Nota 1 a la entrada: La información puede relacionarse con la existencia, naturaleza, forma, probabilidad (3.1.13), importancia, evaluación, aceptación y tratamiento del riesgo.

Nota 2 a la entrada: La consulta es un proceso bidireccional de comunicación informada entre una organización y sus partes interesadas sobre un asunto antes de tomar una decisión o determinar una dirección al respecto. La consulta es:

— un proceso que incide en una decisión a través de la influencia en lugar del poder;

— una contribución a la toma de decisiones, no una toma de decisiones conjunta.

3.2.3

Evaluación de riesgos

proceso general de identificación de riesgos (3.2.4), análisis de riesgos (3.2.5) y evaluación de riesgos (3.2.6)

[FUENTE: Guía ISO 73:2009, 3.4.1]

3.2.4

identificación de riesgos

proceso de encontrar, reconocer y describir riesgos (3.1.3)

Nota 1 a la entrada: La identificación de riesgos implica la identificación de las fuentes de riesgo (3.1.6), los eventos (3.1.11), sus causas y sus posibles consecuencias (3.1.14).

Nota 2 a la entrada: La identificación de riesgos puede involucrar datos históricos, análisis teórico, opiniones informadas y de expertos y las necesidades de las partes interesadas.

[FUENTE: Guía ISO 73:2009, 3.5.1, modificada — "parte interesada" ha reemplazado a "parte interesada" en la Nota 2 de la entrada.]

3.2.5

análisis de riesgos

proceso para comprender la naturaleza del riesgo (3.1.3) y determinar el nivel de riesgo (3.1.15)

Nota 1 a la entrada: El análisis de riesgos proporciona la base para la evaluación de riesgos (3.2.6) y las decisiones sobre el tratamiento de los riesgos. (3.2.7).

Nota 2 a la entrada: El análisis de riesgos incluye la estimación de riesgos.

[FUENTE: Guía ISO 73:2009, 3.6.1]

3.2.6

evaluación de riesgos

proceso de comparar los resultados del análisis de riesgos (3.2.5) con los criterios de riesgo (3.1.7) para determinar si el riesgo (3.1.3) y/o su importancia son aceptables o tolerables

Nota 1 a la entrada: La evaluación de riesgos ayuda a tomar decisiones sobre el tratamiento de los riesgos (3.2.7).

[FUENTE: Guía ISO 73:2009, 3.7.1, modificada — "significación" ha reemplazado a "magnitud".]

ISO/IEC 27005:2022(E)

3.2.7

proceso de tratamiento

de riesgos para modificar el riesgo ~~(3.1.3)~~

Nota 1 a la entrada: El tratamiento del riesgo puede implicar:

- evitar el riesgo decidiendo no iniciar o continuar con la actividad que genera el riesgo;
- asumir o aumentar riesgos para aprovechar una oportunidad;
- eliminar la fuente de riesgo (3.1.6); _____
- cambiar la probabilidad (3.1.13); _____
- cambiar las consecuencias (3.1.14); _____
- compartir el riesgo con otra o varias partes (incluidos los contratos y la financiación del riesgo); y
- conservar el riesgo mediante una decisión informada.

Nota 2 a la entrada: El tratamiento del riesgo de seguridad de la información no incluye "asumir o aumentar el riesgo para aprovechar una oportunidad", pero la organización puede tener esta opción para la gestión general del riesgo.

Nota 3 a la entrada: Los tratamientos de riesgo que abordan las consecuencias negativas a veces se denominan "mitigación de riesgo", "eliminación de riesgo", "prevención de riesgo" y "reducción de riesgo".

Nota 4 a la entrada: El tratamiento del riesgo puede crear nuevos riesgos o modificar los existentes.

[FUENTE: Guía ISO 73:2009, 3.8.1, modificada — Se ha añadido la Nota 1 a la entrada y las Notas 1 y 2 originales a la entrada se han reenumerado como Notas 2 y 3 a la entrada.]

3.2.8

aceptación del riesgo

decisión informada de asumir un riesgo particular (3.1.3) _____

Nota 1 a la entrada: La aceptación del riesgo puede ocurrir sin tratamiento del riesgo (3.2.7) o durante el proceso de tratamiento del riesgo.

Nota 2 a la entrada: Los riesgos aceptados están sujetos a seguimiento y revisión.

[FUENTE: Guía ISO 73:2009, 3.7.1.6]

3.2.9

reparto de riesgos

forma de tratamiento de riesgos ~~(3.2.7)~~ que implica la distribución acordada del riesgo (3.1.3) con ~~otra~~ partes

Nota 1 a la entrada: Los requisitos legales o reglamentarios pueden limitar, prohibir o exigir la distribución de riesgos.

Nota 2 a la entrada: La distribución del riesgo puede realizarse mediante seguros u otras formas de contrato.

Nota 3 a la entrada: El grado en que se distribuye el riesgo puede depender de la fiabilidad y claridad de los acuerdos de distribución.

Nota 4 a la entrada: La transferencia de riesgos es una forma de compartir riesgos.

[FUENTE: Guía ISO 73:2009, 3.8.1.3]

3.2.10

retención de riesgo

aceptación temporal del beneficio potencial de ganancia o carga de pérdida de un riesgo particular (3.1.3) _____

Nota 1 a la entrada: La retención puede restringirse a un período de tiempo determinado.

Nota 2 a la entrada: El nivel de riesgo (3.1.15) retenido puede depender de los criterios de riesgo (3.1.7). _____

[FUENTE: Guía ISO 73:2009, 3.8.1.5, modificada: se agregó la palabra “temporal” al comienzo de la definición y la frase “La retención de riesgos incluye la aceptación de riesgos residuales” reemplazó “La retención puede restringirse a un cierto período de tiempo” en la Nota 1 de la entrada.]

4 Estructura de este documento

El presente documento está estructurado de la siguiente manera:

- [Cláusula 5](#): Gestión de riesgos de seguridad de la información;
- [Cláusula 6](#): Establecimiento del contexto;
- [Cláusula 7](#): Proceso de evaluación de riesgos de seguridad de la información;
- [Cláusula 8](#): Proceso de tratamiento de riesgos de seguridad de la información;
- [Cláusula 9](#): Funcionamiento;
- [Cláusula 10](#): Aprovechamiento de los procesos SGSI relacionados.

Salvo las descripciones dadas en las subcláusulas generales, todas las actividades de gestión de riesgos presentadas desde [la Cláusula 7](#) a [la Cláusula 10](#) se estructuran de la siguiente manera:

Entrada: Identifica cualquier información requerida para realizar la actividad.

Acción: Describe la actividad.

Disparador: Proporciona orientación sobre cuándo iniciar la actividad, por ejemplo, debido a un cambio dentro de la organización o de acuerdo con un plan o un cambio en el contexto externo de la organización.

Salida: Identifica cualquier información derivada después de realizar la actividad, así como cualquier criterio que dicha salida debe satisfacer.

Orientación: Proporciona orientación sobre la realización de la actividad, palabra clave y concepto clave.

5 Gestión de riesgos de seguridad de la información

5.1 Proceso de gestión de riesgos de seguridad de la información

El proceso de gestión de riesgos de seguridad de la información se presenta en [la Figura 1](#). 

NOTA Este proceso se basa en el proceso general de gestión de riesgos definido en la norma ISO 31000.

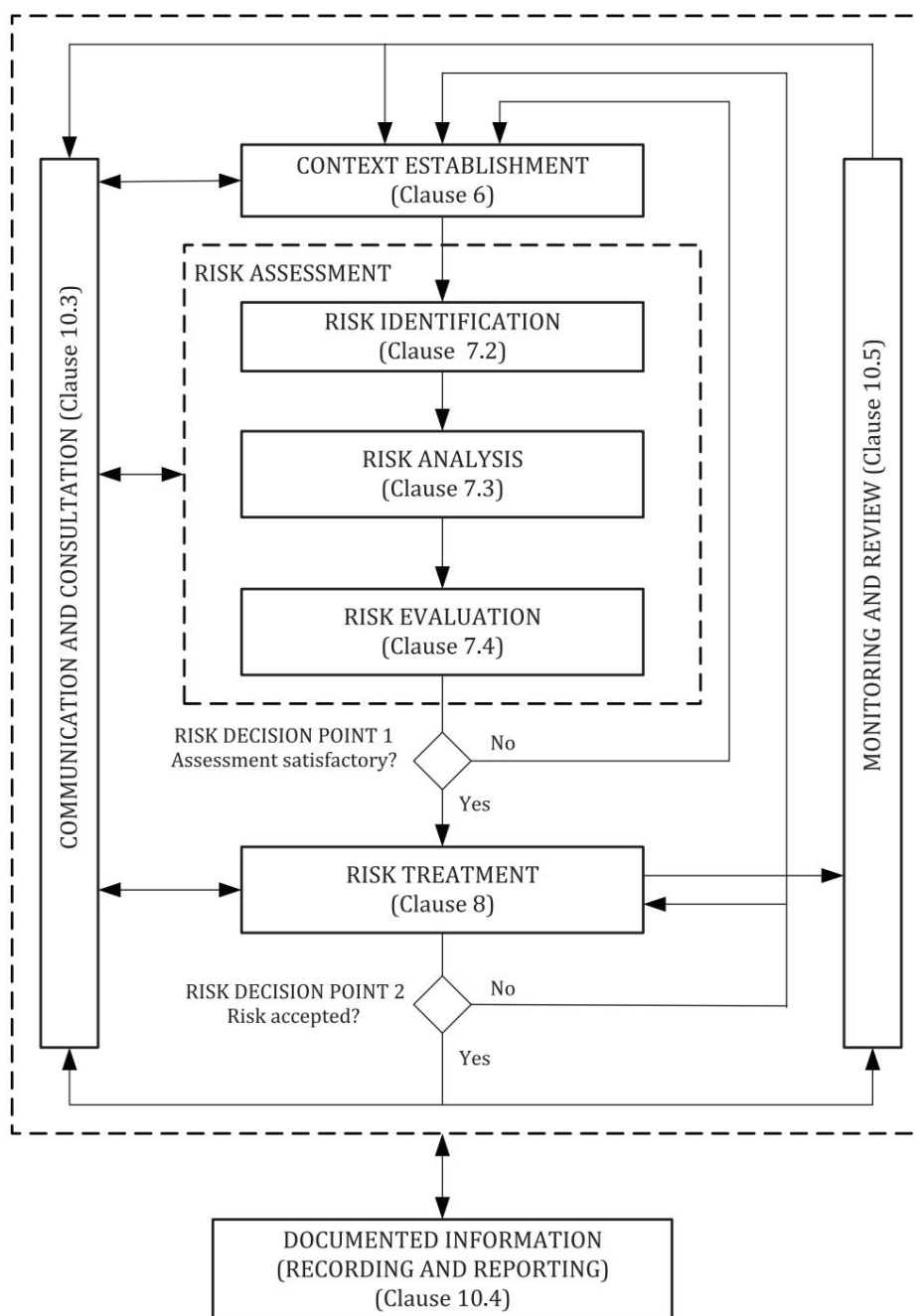


Figura 1 — Proceso de gestión de riesgos de seguridad de la información

Como ilustra la Figura 1, el proceso de gestión de riesgos de seguridad de la información puede ser iterativo para las actividades de evaluación y/o tratamiento de riesgos. Un enfoque iterativo para la evaluación de riesgos puede aumentar la profundidad y el detalle de la evaluación en cada iteración. El enfoque iterativo proporciona un buen equilibrio entre minimizar el tiempo y el esfuerzo dedicados a la identificación de controles, a la vez que garantiza que los riesgos se evalúen adecuadamente.

Establecer el contexto significa reunir el contexto interno y externo para la gestión de riesgos de seguridad de la información o una evaluación de riesgos de seguridad de la información.

Si la evaluación de riesgos proporciona información suficiente para determinar eficazmente las acciones necesarias para modificar los riesgos a un nivel aceptable, entonces la tarea está completa y se procede al tratamiento del riesgo. Si la información es insuficiente, se debe realizar otra iteración de la evaluación de riesgos. Esto puede implicar un cambio de contexto de la evaluación de riesgos (por ejemplo, la revisión del alcance), la participación de expertos en

el campo relevante u otras formas de recopilar la información necesaria para permitir la modificación del riesgo a un nivel aceptable (véase el "punto de decisión de riesgo 1" en [la Figura 1](#)). _____

El tratamiento del riesgo implica un proceso iterativo de:

- formular y seleccionar opciones de tratamiento de riesgos;
- planificar y ejecutar el tratamiento de riesgos;
- evaluar la eficacia de dicho tratamiento;
- decidir si el riesgo restante es aceptable;
- tomar tratamiento adicional si no es aceptable.

Es posible que el tratamiento de riesgos no genere inmediatamente un nivel aceptable de riesgos residuales. En este caso, se puede intentar encontrar un tratamiento adicional o realizar otra iteración de la evaluación de riesgos, ya sea completa o parcial. Esto puede implicar un cambio de contexto en la evaluación de riesgos (por ejemplo, mediante la revisión del alcance) y la participación de expertos en el campo pertinente. El conocimiento de las amenazas o vulnerabilidades relevantes puede permitir tomar mejores decisiones sobre las actividades adecuadas de tratamiento de riesgos en la siguiente iteración de la evaluación de riesgos (véase el "punto de decisión sobre riesgos 2" en [la Figura 1](#)). _____

El establecimiento del contexto se analiza en detalle en [la Cláusula 6](#), las actividades de evaluación de riesgos en [la Cláusula 7](#) y las actividades de tratamiento de riesgos en [la Cláusula 8](#).

Otras actividades necesarias para gestionar los riesgos de seguridad de la información se analizan en [la Cláusula 10](#). _____

5.2 Ciclos de gestión de riesgos de seguridad de la información

La evaluación y el tratamiento de riesgos deben actualizarse periódicamente y en función de los cambios. Esto debe aplicarse a toda la evaluación de riesgos, y las actualizaciones pueden dividirse en dos ciclos de gestión de riesgos:

- ciclo estratégico, donde los activos del negocio, las fuentes de riesgo y amenazas, los objetivos o las consecuencias de los eventos de seguridad de la información evolucionan a partir de los cambios en el contexto general de la organización. Esto puede servir como insumo para una actualización general de la evaluación de riesgos, o de las evaluaciones de riesgos y sus tratamientos. También puede servir como insumo para identificar nuevos riesgos e iniciar evaluaciones de riesgos completamente nuevas.
- ciclo operativo, donde los elementos mencionados sirven como información de entrada o criterios modificados que afectarán una evaluación de riesgos, donde los escenarios deben revisarse y actualizarse. La revisión debe incluir la actualización del tratamiento de riesgos correspondiente, según corresponda.

El ciclo estratégico debe llevarse a cabo en un período de tiempo más largo o cuando ocurren cambios importantes, mientras que el ciclo operativo debe ser más corto dependiendo de los riesgos detallados que se identifican y evalúan, así como del tratamiento de riesgos relacionado.

El ciclo estratégico se aplica al entorno en el que la organización busca alcanzar sus objetivos, mientras que el ciclo operativo se aplica a todas las evaluaciones de riesgos, considerando el contexto del proceso de gestión de riesgos. En ambos ciclos, puede haber múltiples evaluaciones de riesgos con diferentes contextos y alcances.

6 Establecimiento del contexto

6.1 Consideraciones organizativas

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 4.1.

Una organización se define como una persona o grupo de personas que tiene sus propias funciones, con responsabilidades, autoridad y relaciones para lograr sus objetivos. Una organización no es necesariamente una empresa,

otra entidad corporativa o jurídica, también puede ser un subconjunto de una entidad jurídica (por ejemplo, el departamento de TI de una empresa), y puede considerarse como la “organización” dentro del contexto del SGSI.

Es importante comprender que el apetito de riesgo, definido como la cantidad de riesgo que una organización está dispuesta a asumir o aceptar, puede variar considerablemente de una organización a otra. Por ejemplo, los factores que influyen en el apetito de riesgo de una organización incluyen el tamaño, la complejidad y el sector. La alta dirección debe establecer y revisar periódicamente el apetito de riesgo.

La organización debe garantizar que el rol del responsable del riesgo esté definido en función de las actividades de gestión de los riesgos identificados. Los responsables del riesgo deben tener la responsabilidad y la autoridad adecuadas para gestionar los riesgos identificados.

6.2 Identificación de los requisitos básicos de las partes interesadas

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 4.2.

Se deben identificar los requisitos básicos de las partes interesadas pertinentes, así como su grado de cumplimiento. Esto incluye la identificación de todos los documentos de referencia que definen las normas y controles de seguridad y que son aplicables en el ámbito de la evaluación de riesgos de seguridad de la información.

Estos documentos de referencia pueden incluir, entre otros:

- a) ISO/IEC 27001:2022, Anexo A;
- b) normas adicionales que cubran el SGSI;
- c) normas adicionales aplicables a un sector específico (por ejemplo, financiero, sanitario);
- d) reglamentaciones internacionales y/o nacionales específicas;
- e) las normas de seguridad interna de la organización;
- f) normas y controles de seguridad derivados de contratos o acuerdos;
- g) controles de seguridad implementados con base en actividades previas de tratamiento de riesgos.

Cualquier incumplimiento de los requisitos básicos debe explicarse y justificarse. Estos requisitos básicos y su cumplimiento deben constituir la base para la evaluación de probabilidad y el tratamiento del riesgo.

6.3 Aplicación de la evaluación de riesgos

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 4.3.

Las organizaciones pueden realizar evaluaciones de riesgos integradas en diversos procesos, como la gestión de proyectos, la gestión de vulnerabilidades, la gestión de incidentes, la gestión de problemas, o incluso de forma improvisada para un tema específico identificado. Independientemente de cómo se realicen las evaluaciones de riesgos, estas deben abarcar colectivamente todos los problemas relevantes para la organización dentro del alcance de... un SGSI.

La evaluación de riesgos debe ayudar a la organización a tomar decisiones sobre la gestión de los riesgos que afectan el logro de sus objetivos. Por lo tanto, debe centrarse en aquellos riesgos y controles que, si se gestionan correctamente, mejorarán la probabilidad de que la organización alcance sus objetivos.

Se proporciona más información sobre el contexto de un SGSI y las cuestiones que deben entenderse a través de la evaluación de riesgos en la norma ISO/IEC 27003.

6.4 Establecer y mantener criterios de riesgo de seguridad de la información

6.4.1 General

ISO/IEC 27001:2022, 6.1.2 a), especifica los requisitos para que las organizaciones definan sus criterios de riesgo, es decir, los términos de referencia mediante los cuales evalúan la importancia de los riesgos que identifican y toman decisiones sobre los mismos.

La norma ISO/IEC 27001 especifica los requisitos para que una organización establezca y mantenga criterios de riesgo de seguridad de la información que incluyan:

- a) los criterios de aceptación del riesgo;
- b) criterios para realizar evaluaciones de riesgos de seguridad de la información.

En general, para establecer criterios de riesgo se debe considerar lo siguiente:

- la naturaleza y el tipo de incertidumbres que pueden afectar los resultados y objetivos (tanto tangibles como intangible);
- cómo se definirán, predecirán y medirán las consecuencias y la probabilidad;
- factores relacionados con el tiempo;
- consistencia en el uso de las mediciones;
- cómo se determinará el nivel de riesgo;
- cómo se tendrán en cuenta las combinaciones y secuencias de riesgos múltiples;
- la capacidad de la organización.

En el [Anexo A](#) se presentan más consideraciones sobre los criterios de riesgo.

6.4.2 Criterios de aceptación de riesgos

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.2 a) 1).

En la evaluación de riesgos, se deben utilizar criterios de aceptación de riesgos para determinar si un riesgo es aceptable o no.

En el tratamiento del riesgo, se pueden utilizar criterios de aceptación del riesgo para determinar si el tratamiento del riesgo propuesto es suficiente para alcanzar un nivel de riesgo aceptable o si se necesita un tratamiento del riesgo adicional.

Una organización debe definir niveles de aceptación de riesgos. Durante el desarrollo, se debe considerar lo siguiente:

- a) la coherencia entre los criterios de aceptación de riesgos de seguridad de la información y los de la organización; criterios generales de aceptación de riesgos;
- b) se identifica el nivel de gestión con autoridad delegada para tomar decisiones de aceptación de riesgos;
- c) los criterios de aceptación de riesgos pueden incluir múltiples umbrales y la autoridad para la aceptación puede asignarse a diferentes niveles de gestión;
- d) los criterios de aceptación de riesgos pueden basarse únicamente en la probabilidad y las consecuencias, o pueden ampliarse para considerar también el equilibrio costo/beneficio entre las pérdidas potenciales y el costo de los controles;
- e) pueden aplicarse diferentes criterios de aceptación de riesgos a diferentes clases de riesgos (por ejemplo, los riesgos que pueden dar lugar a un incumplimiento de las reglamentaciones o leyes no siempre se tienen en cuenta, mientras que la aceptación de riesgos puede permitirse si la aceptación es resultado de un requisito contractual);

ISO/IEC 27005:2022(E)

- f) los criterios de aceptación de riesgos pueden incluir requisitos para un tratamiento adicional futuro (por ejemplo, un riesgo puede conservarse a corto plazo incluso cuando el nivel de riesgo excede los criterios de aceptación de riesgos si existe aprobación y compromiso de tomar medidas para implementar un conjunto elegido de controles para alcanzar un nivel aceptable dentro de un período de tiempo definido);
- g) los criterios de aceptación de riesgos deben definirse con base en el apetito de riesgo, que indica la cantidad y el tipo de riesgo que la organización está dispuesta a asumir o retener;
- h) Los criterios de aceptación de riesgos pueden ser absolutos o condicionales según el contexto.

Los criterios de aceptación de riesgos deberán establecerse considerando los siguientes factores influyentes:

- objetivos organizacionales;
- oportunidades de organización;
- aspectos legales y reglamentarios;
- actividades operativas;
- limitaciones tecnológicas;
- limitaciones financieras;
- procesos;
- relaciones con proveedores;
- factores humanos (por ejemplo, relacionados con la privacidad).

La lista de factores influyentes no es exhaustiva. La organización debe considerarlos según el contexto.

Un simple criterio de aceptación (sí/no) no siempre es suficiente en la práctica.

En muchos casos, la decisión de aceptar el riesgo puede tomarse a niveles específicos de riesgo (combinaciones específicas de probabilidad y consecuencia). Sin embargo, puede haber circunstancias en las que sea necesario establecer umbrales de aceptación para consecuencias extremas, independientemente de su probabilidad, o para probabilidades extremadamente altas, independientemente de las consecuencias, donde el efecto en la organización se deba principalmente a una u otra.

Por ejemplo, la aceptación de un evento raro que elimine el valor de las acciones de una empresa, o un drenaje constante de recursos que resulta de la necesidad de controlar frecuentes infracciones menores de una política, debe considerarse principalmente en función de cuál de los dos factores tiene el efecto dominante sobre la organización.

Por consiguiente, los criterios de aceptación de riesgos deberían idealmente incluir la consideración de la probabilidad y la consecuencia de forma independiente, así como los costos de gestión, en lugar de simplemente el nivel de riesgo como una combinación de probabilidad y consecuencia.

Una organización con un alto nivel de tolerancia al riesgo puede establecer un umbral de aceptación más alto, aceptando así más riesgos que una organización con un nivel menor. Esto la protege del control excesivo, es decir, de tener tantos controles de seguridad de la información que le impiden alcanzar sus objetivos.

Los criterios de aceptación de riesgos pueden variar dependiendo de cuánto tiempo se espera que existan los riesgos (por ejemplo, los riesgos pueden estar asociados con una actividad temporal o de corto plazo).

Los criterios de riesgo deben mantenerse bajo revisión y actualizarse según sea necesario como resultado de cualquier cambio en el contexto de la gestión de riesgos de seguridad de la información.

EJEMPLO Una empresa pequeña puede tener inicialmente un gran apetito por el riesgo, pero a medida que crece, puede reducirlo.

Los criterios de aceptación de riesgos deberán ser aprobados por el nivel directivo autorizado.

6.4.3 Criterios para realizar evaluaciones de riesgos de seguridad de la información

6.4.3.1 General

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.2 a) 2).

Los criterios de evaluación de riesgos especifican cómo se determina la importancia de un riesgo en términos de sus consecuencias, probabilidad y nivel de riesgo.

Los criterios de evaluación de riesgos de seguridad de la información deben tener en cuenta la idoneidad de las actividades de gestión de riesgos.

Las consideraciones para lograr esto incluyen:

- a) el nivel de clasificación de la información;
- b) la cantidad y cualquier concentración de información;
- c) el valor estratégico de los procesos de negocio que hacen uso de la información;
- d) la criticidad de la información y de los activos relacionados con la información involucrada;
- e) importancia operativa y comercial de la disponibilidad, confidencialidad e integridad;
- f) las expectativas y percepciones de las partes interesadas (por ejemplo, la alta dirección);
- g) consecuencias negativas como pérdida de buena voluntad y reputación;
- h) coherencia con los criterios de riesgo organizacional.

Los criterios de evaluación de riesgos, o una base formal para definirlos, deben estandarizarse en toda la organización para todos los tipos de evaluación de riesgos, ya que esto puede facilitar la comunicación, comparación y agregación de los riesgos asociados con múltiples dominios comerciales.

Los criterios de evaluación de riesgos de seguridad de la información suelen incluir:

- consecuencias;
- probabilidad;
- nivel de riesgo.

6.4.3.2 Criterios de consecuencia

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.2 a) 2).

La norma ISO/IEC 27001 se ocupa de las consecuencias que se ven afectadas directa o indirectamente por la preservación o pérdida de la confidencialidad, integridad y disponibilidad de la información en el alcance del SGSI.

Los criterios de consecuencia deben desarrollarse y especificarse en función del alcance del daño, la pérdida o el perjuicio que pueda sufrir una organización o un individuo como resultado de la pérdida de confidencialidad, integridad y disponibilidad de la información. Al definir los criterios de consecuencia, se debe considerar especialmente lo siguiente:

- a) pérdida de vidas o daños a personas o grupos;
- b) pérdida de la libertad, de la dignidad o del derecho a la intimidad;
- c) pérdida de personal y capital intelectual (habilidades y experiencia);
- d) operaciones internas o de terceros deterioradas (por ejemplo, daños a una función o proceso empresarial);
- e) efectos sobre los planes y plazos;

ISO/IEC 27005:2022(E)

- f) pérdida de valor comercial y financiero;
- g) pérdida de ventaja comercial o de cuota de mercado;
- h) daño a la confianza o reputación pública;
- i) incumplimientos de requisitos legales, reglamentarios o estatutarios;
- j) incumplimientos de contratos o niveles de servicio;
- k) impacto adverso sobre las partes interesadas;
- l) impacto negativo sobre el medio ambiente, contaminación.

Los criterios de consecuencia definen cómo una organización categoriza la importancia de los posibles eventos de seguridad de la información. Es fundamental determinar cuántas categorías de consecuencias se utilizan, cómo se definen y qué consecuencias se asocian a cada categoría. Normalmente, los criterios de consecuencia varían según la organización, dependiendo de su contexto interno y externo.

EJEMPLO 1 El monto máximo que la organización está dispuesta a amortizar en un año fiscal y el monto mínimo en el mismo período que la obligaría a la liquidación pueden crear límites superiores e inferiores realistas de la escala de consecuencias de una organización expresada en términos monetarios.

Este rango, dependiente del contexto, puede dividirse en varias categorías de consecuencias, cuyo número y distribución dependerán de la percepción y el nivel de riesgo de la organización. Las escalas de consecuencias monetarias suelen expresarse en escalas logarítmicas, como décadas o potencias de 10 (p. ej., 100 a 1000; 1 a 10 000, etc.), pero se pueden utilizar esquemas de cuantificación alternativos cuando se ajusten mejor al contexto de la organización.

Dado que las consecuencias en los diferentes dominios o departamentos de una organización pueden expresarse inicialmente de diversas maneras, en lugar de solo en términos monetarios, resulta útil comparar estas diversas expresiones con una escala de referencia común para garantizar que se comparen correctamente niveles de consecuencia aproximadamente equivalentes en los diferentes dominios. Esto debería permitir la agregación de riesgos entre dominios.

EJEMPLO 2 Una filtración de datos, además de afectar la privacidad individual, puede resultar en la pérdida de confidencialidad, integridad o disponibilidad de la información dentro del ámbito del SGSI. Esto también puede conllevar el incumplimiento de la legislación aplicable en materia de protección de datos. Las posibles consecuencias van desde la pérdida de información, la pérdida de activos y procesos relacionados con la información, hasta la pérdida de los objetivos operativos y las proyecciones de negocio.

6.4.3.3 Criterios de probabilidad

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.2 a) 2).

La determinación de los criterios de verosimilitud depende de aspectos como:

- a) acontecimientos accidentales o naturales;
- b) el grado de exposición de la información relevante o del activo relacionado con la información a la amenaza;
- c) el grado en que se explota la vulnerabilidad de la organización;
- d) fallo tecnológico;
- e) actos u omisiones humanos.

La probabilidad puede expresarse en términos probabilísticos (la probabilidad de que un evento ocurra en un período determinado) o en términos frecuentistas (el promedio teórico de ocurrencias en un período determinado). La probabilidad expresada en términos relacionados con la frecuencia se utiliza a menudo al comunicarla, aunque solo la probabilidad expresada en términos probabilísticos puede utilizarse al realizar la agregación de probabilidades.

Los criterios de probabilidad deberían cubrir el rango predeciblemente manejable de probabilidades anticipadas de eventos. Más allá de los límites de la manejabilidad practicable, normalmente solo es necesario reconocer que se ha excedido uno u otro límite para tomar una decisión adecuada de gestión de riesgos (designación como caso extremo). Si las escalas finitas son demasiado amplias, esto suele resultar en una cuantificación excesivamente burda y puede generar errores de evaluación. Esto ocurre especialmente cuando las probabilidades se sitúan en el extremo superior de las escalas representadas exponencialmente, ya que los incrementos en los rangos superiores son intrínsecamente muy amplios.

Aunque casi todo es “posible”, las fuentes de riesgo a las que se debe prestar atención principal son aquellas con probabilidades más relevantes para el contexto de la organización y el alcance de su SGSI.

6.4.3.4 Criterios para determinar el nivel de riesgo

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.2 a) 2).

El propósito de las escalas de nivel de riesgo es ayudar a los responsables de los riesgos a decidir si retenerlos o tratarlos de otra manera, y a priorizarlos para su tratamiento. El nivel evaluado de un riesgo en particular debería ayudar a la organización a determinar la urgencia de abordarlo.

Según la situación, se recomienda considerar el nivel de riesgo inherente (sin considerar ningún control) o el nivel de riesgo actual (considerando la eficacia de los controles ya implementados). La organización debe desarrollar una clasificación de riesgos, considerando lo siguiente:

- a) los criterios de consecuencia y los criterios de probabilidad;
- b) las consecuencias que los eventos de seguridad de la información pueden tener a nivel estratégico, táctico y operativo (esto puede definirse como el peor de los casos o en otros términos siempre que se utilice consistentemente la misma base);
- c) requisitos legales y reglamentarios y obligaciones contractuales;
- d) los riesgos que aparecen más allá de los límites del alcance de la organización, incluidos los efectos imprevistos sobre terceros.

Los criterios de nivel de riesgo son necesarios para evaluar los riesgos analizados.

Los criterios para determinar el nivel de riesgo pueden ser cualitativos (por ejemplo, muy alto, alto, medio, bajo) o cuantitativos (por ejemplo, expresados en términos de valor esperado de pérdida monetaria, pérdida de vidas o cuota de mercado durante un período de tiempo determinado).

EJEMPLO Los riesgos pueden cuantificarse como expectativa de pérdida anual, es decir, el valor monetario promedio de la consecuencia por año asumido durante el año siguiente.

Independientemente de que se utilicen criterios cuantitativos o cualitativos, las escalas de evaluación deben, en última instancia, estar ancladas a una escala de referencia que sea entendida por todas las partes interesadas, y tanto el análisis como la evaluación de riesgos deben incluir al menos una calibración formal periódica con respecto a la escala de referencia para garantizar la validez, la consistencia y la comparabilidad de los resultados.

Si se utiliza un enfoque cualitativo, los niveles de cualquier escala cualitativa deben ser inequívocos, sus incrementos deben estar claramente definidos, las descripciones cualitativas de cada nivel deben expresarse en un lenguaje objetivo y los niveles no deben solaparse. Cuando se utilicen diferentes escalas (por ejemplo, para abordar riesgos en diferentes áreas de negocio), debe existir una equivalencia que permita obtener resultados comparables.

6.5 Elección de un método apropiado

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.2 b).

En general, el enfoque y los métodos de gestión de riesgos de seguridad de la información deben estar alineados con el enfoque y los métodos utilizados para gestionar los demás riesgos de la organización.

El enfoque elegido debe documentarse.

ISO/IEC 27005:2022(E)

Según la norma ISO/IEC 27001:2022, apartado 6.1.2 b), la organización, dentro del alcance del SGSI, debe garantizar que las evaluaciones repetidas de riesgos de seguridad de la información produzcan resultados consistentes, válidos y comparables. Esto significa que el método elegido debe garantizar las siguientes propiedades de los resultados:

- coherencia: evaluaciones de los mismos riesgos realizadas por diferentes personas o por las mismas personas en diferentes ocasiones, en el mismo contexto, deberían producir resultados similares;
- comparabilidad: deben definirse criterios de evaluación de riesgos para garantizar que las evaluaciones realizadas para diferentes riesgos produzcan resultados comparables cuando representen niveles equivalentes de riesgo;
- validez: las evaluaciones deben producir resultados que concuerden lo más posible con la realidad.

Los métodos de gestión de riesgos operativos se utilizan normalmente para la gestión de riesgos de seguridad de la información. El método elegido puede emplear cualquier enfoque adecuado en relación con el uso del riesgo residual. Los enfoques más comunes para la gestión de riesgos de seguridad de la información utilizan el riesgo actual al evaluar la probabilidad y las consecuencias de los riesgos.

7 Proceso de evaluación de riesgos de seguridad de la información

7.1 General

La organización debe utilizar el proceso de evaluación de riesgos organizacionales (si está establecido) para evaluar los riesgos a la información o para definir un proceso de evaluación de riesgos de seguridad de la información.

La evaluación de riesgos permite a los propietarios de riesgos priorizar los riesgos alineados con la perspectiva del tratamiento, basándose principalmente en sus consecuencias y probabilidad u otros criterios establecidos.

Se debe determinar el contexto de la evaluación de riesgos, incluida una descripción del alcance y el propósito, así como cuestiones internas y externas que afectan la evaluación de riesgos.

La evaluación de riesgos consta de las siguientes actividades:

- a) identificación de riesgos, que es un proceso para encontrar, reconocer y describir los riesgos (más detalles sobre los riesgos La identificación se proporciona en [7.2](#));
- b) Análisis de riesgos, que es un proceso para comprender los tipos de riesgo y determinar su nivel. El análisis de riesgos implica considerar las causas y fuentes del riesgo, la probabilidad de que ocurra un evento específico, la probabilidad de que este tenga consecuencias y la gravedad de dichas consecuencias (se proporcionan más detalles sobre el análisis de riesgos en el [apartado 7.3](#)).
- c) Evaluación de riesgos, que consiste en comparar los resultados del análisis de riesgos con los criterios de riesgo para determinar si el riesgo o su importancia son aceptables y priorizar los riesgos analizados para su tratamiento. Con base en esta comparación, se puede considerar la necesidad de tratamiento (se proporcionan más detalles sobre la evaluación de riesgos en el [apartado 7.4](#)).

El proceso de evaluación de riesgos debe basarse en métodos (véase [6.5](#)) y herramientas diseñados con el suficiente detalle para garantizar, en la medida de lo posible, resultados consistentes, válidos y reproducibles. Además, los resultados deben ser comparables, por ejemplo, para determinar si el nivel de riesgo aumentó o disminuyó.

La organización debe asegurarse de que su enfoque de gestión de riesgos de seguridad de la información esté alineado con el enfoque de gestión de riesgos organizacionales, de modo que cualquier riesgo de seguridad de la información pueda compararse con otros riesgos organizacionales y no solo considerarse de forma aislada.

La norma ISO/IEC 27001 no exige un enfoque específico para cumplir con los requisitos de la norma ISO/IEC 27001:2022, apartado 6.1.2. Sin embargo, existen dos enfoques principales de evaluación: uno basado en eventos y otro basado en activos. Se describen con más detalle en el [apartado 7.2.1](#).

7.2 Identificación de riesgos de seguridad de la información

7.2.1 Identificación y descripción de los riesgos de seguridad de la información

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.2 c) 1).

Entrada: Eventos que pueden influir negativamente en el logro de los objetivos de seguridad de la información en la organización o en otras organizaciones.

Acción: Se deben identificar los riesgos asociados a la pérdida de confidencialidad, integridad y disponibilidad de la información.

Desencadenante: Los propietarios de riesgos, las partes interesadas y/o los expertos detectan, o tienen la necesidad de buscar, eventos o situaciones nuevas o modificadas que puedan afectar el logro de los objetivos de seguridad de la información.

Resultado: Una lista de riesgos identificados.

Guía de implementación: _____

La identificación de riesgos es el proceso de encontrar, reconocer y describir los riesgos. Esto implica la identificación de las fuentes y eventos de riesgo.

El objetivo de la identificación de riesgos es generar una lista de riesgos basada en aquellos eventos que pueden impedir, afectar o retrasar el logro de los objetivos de seguridad de la información.

Los riesgos identificados deben ser aquellos que, de materializarse, pueden tener efecto sobre el logro de los objetivos.

La norma ISO/IEC 27001:2022, 6.1.2 c), exige que la organización defina y aplique un proceso de evaluación de riesgos de seguridad de la información que identifique dichos riesgos. Existen dos enfoques comunes para la identificación de riesgos.

- a) Enfoque basado en eventos: identificar escenarios estratégicos a través de una consideración de las fuentes de riesgo y cómo las utilizan o impactan a las partes interesadas para alcanzar el objetivo deseado de esos riesgos.
- b) Enfoque basado en activos: identificar escenarios operativos, que se detallan en términos de activos, amenazas y vulnerabilidades.

En un enfoque basado en eventos, el concepto subyacente es que los riesgos pueden identificarse y evaluarse mediante la evaluación de eventos y consecuencias. Estos eventos y consecuencias a menudo pueden determinarse mediante el descubrimiento de las preocupaciones de la alta dirección, los responsables de los riesgos y los requisitos identificados al determinar el contexto de la organización (ISO/IEC 27001:2022, Cláusula 4). Las entrevistas con la alta dirección y las personas de la organización responsables de un proceso de negocio pueden ayudar a identificar no solo los eventos y consecuencias relevantes, sino también a los responsables de los riesgos.

Un enfoque basado en eventos permite establecer escenarios estratégicos o de alto nivel sin invertir mucho tiempo en la identificación detallada de activos. Esto permite a la organización centrar sus esfuerzos en el tratamiento de riesgos en los riesgos críticos. La evaluación de eventos mediante este enfoque puede utilizar datos históricos donde los riesgos permanecen invariables durante largos periodos, lo que permite a las partes interesadas alcanzar sus objetivos. Sin embargo, en el caso de riesgos para los que no se dispone de datos históricos o no son fiables, el asesoramiento basado en el conocimiento y la experiencia de expertos o la investigación de las fuentes de riesgo pueden facilitar la evaluación.

Con un enfoque basado en activos, el concepto subyacente es que los riesgos pueden identificarse y evaluarse mediante la inspección de activos, amenazas y vulnerabilidades. Un activo es cualquier cosa que tenga valor para la organización y, por lo tanto, requiera protección. Los activos deben identificarse, teniendo en cuenta que un sistema de información consta de actividades, procesos e información que deben protegerse. Los activos pueden identificarse como activos principales y de apoyo según su tipo y prioridad, destacando sus dependencias, así como sus interacciones con las fuentes de riesgo y las partes interesadas de la organización. Una amenaza explota la vulnerabilidad de un activo para comprometer la confidencialidad, la integridad o la disponibilidad de la información correspondiente. Si se consideran todas las combinaciones válidas de activos, amenazas y vulnerabilidades...

ISO/IEC 27005:2022(E)

Si se pueden enumerar dentro del alcance del SGSI, entonces, en teoría, se identificarían todos los riesgos. Para los pasos posteriores de la evaluación de riesgos, se debe elaborar una lista de activos asociados con la información y las instalaciones de procesamiento de la información.

El enfoque basado en activos puede identificar amenazas y vulnerabilidades específicas de cada activo y permite a la organización determinar un tratamiento de riesgo específico a un nivel detallado.

En el [Anexo A](#) se ofrece más información sobre ambos enfoques.

En principio, ambos enfoques difieren únicamente en el nivel en el que se inicia la identificación.

Ambos enfoques pueden describir el mismo escenario de riesgo; por ejemplo, cuando un activo de información se encuentra a nivel de detalle y una exposición empresarial a nivel general. Identificar las fuentes de riesgo contribuyentes mediante una evaluación basada en eventos suele requerir un análisis a fondo, desde el nivel general del escenario hasta el nivel de detalle, mientras que una evaluación basada en activos suele explorar a nivel superior, desde el activo hasta el escenario, para proporcionar visibilidad sobre cómo se acumulan las consecuencias.

La identificación de riesgos es fundamental, porque un riesgo de seguridad de la información que no se identifica en esta etapa no se incluye en un análisis posterior.

La identificación de riesgos debe considerarlos independientemente de si su origen está bajo el control de la organización, incluso si no se evidencian fuentes de riesgo específicas. En particular, al evaluar escenarios de riesgo complejos, se debe realizar una evaluación iterativa de riesgos. La primera ronda debe centrarse en observaciones de alto nivel y las rondas sucesivas deben abordar niveles adicionales de detalle hasta que se puedan identificar las causas raíz de los riesgos.

Se puede utilizar cualquier otro enfoque de identificación de riesgos siempre que garantice la producción de resultados consistentes, válidos y comparables, cumpliendo el requisito de ISO/IEC 27001:2022, 6.1.2 b).

La gestión de los riesgos de seguridad de la información no debe verse limitada por visiones arbitrarias o restrictivas sobre cómo estructurar, agrupar, agregar, dividir o describir los riesgos. Los riesgos pueden parecer superpuestos o ser subconjuntos o instancias específicas de otros riesgos. Sin embargo, los controles para riesgos individuales deben considerarse e identificarse por separado de los riesgos más amplios o agregados a efectos de la evaluación de riesgos.

EJEMPLO 1 Un ejemplo de dos riesgos superpuestos: (1) existe un riesgo de incendio en la oficina central; (2) existe un riesgo de incendio que afecte el funcionamiento del departamento de contabilidad, cuando este se encuentra en la oficina central pero también en varios otros edificios.

Un ejemplo de instancias específicas de un riesgo: (1) hay un incidente de pérdida de datos; (2) hay un incidente de pérdida de datos personales.

El segundo riesgo es una instancia específica del primer riesgo, pero es probable que tenga atributos y controles diferentes a los del primer riesgo, y puede ser importante gestionarlo por separado del primer riesgo mucho más amplio.

No se debe realizar la agregación de riesgos a menos que sean relevantes entre sí en el contexto de la organización. Al planificar las opciones de tratamiento, puede ser necesario considerar por separado los riesgos que se fusionan para la presupuestación general de la gestión de riesgos, ya que pueden requerirse diferentes controles para gestionarlos.

EJEMPLO 2 Un centro de datos puede estar sujeto a varios peligros independientes: inundaciones, incendios, picos de tensión eléctrica y vandalismo.

Para estimar el nivel general de riesgo corporativo, los riesgos individuales de estos eventos pueden combinarse en un nivel general de riesgo. Sin embargo, dado que cada uno de estos eventos requiere diferentes controles para gestionarlo, deben considerarse e identificarse por separado para su tratamiento. Los riesgos (combinaciones de probabilidades y consecuencias) no siempre pueden agregarse directamente.

7.2.2 Identificación de los propietarios de los riesgos

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.2 c) 2).

Entrada: Lista de riesgos identificados.

Acción: Los riesgos deben estar asociados a los propietarios del riesgo.

Desencadenante: La identificación de los propietarios de los riesgos se hace necesaria cuando:

- no se ha hecho antes;
- se produzca un cambio de personal en el área de negocio pertinente donde residen los riesgos;

Salida: Lista de propietarios de riesgos con riesgos asociados.

Guía de implementación: _____

La alta dirección, el comité de seguridad, los propietarios de procesos, los propietarios funcionales, los gerentes de departamento y los propietarios de activos pueden ser los propietarios del riesgo.

Una organización debe utilizar el proceso de evaluación de riesgos organizacionales (si lo tiene establecido) para identificar a los responsables de los riesgos; de lo contrario, debe definir criterios para ello. Dichos criterios deben tener en cuenta que los responsables de los riesgos:

- son responsables y tienen la autoridad para gestionar los riesgos que les corresponden, es decir, deben tener una posición en la organización que les permita ejercer efectivamente esta autoridad;
- comprender los problemas en cuestión y estar en condiciones de tomar decisiones informadas (por ejemplo, sobre cómo para tratar los riesgos).

El nivel de riesgo y a qué activo debe aplicarse el riesgo pueden servir como base para identificar el riesgo.
propietarios.

La asignación debe realizarse como parte del proceso de evaluación de riesgos.

7.3 Análisis de los riesgos de seguridad de la información

7.3.1 General

El análisis de riesgos tiene como objetivo determinar el nivel del riesgo.

La norma ISO 31000 se menciona en la norma ISO/IEC 27001 como modelo general. La norma ISO/IEC 27001:2022, apartado 6.1.2, exige que, para cada riesgo identificado, el análisis de riesgos se base en la evaluación de sus consecuencias y la probabilidad de ocurrencia para determinar un nivel de riesgo.

Las técnicas de análisis de riesgos basadas en consecuencias y probabilidad pueden ser:

- a) cualitativa, utilizando una escala de atributos calificativos (por ejemplo, alto, medio, bajo); o
- b) cuantitativo, utilizando una escala con valores numéricos (por ejemplo, costo monetario, frecuencia o probabilidad de ocurrencia); o
- c) semicuantitativa, utilizando escalas cualitativas con valores asignados.

El análisis de riesgos debe centrarse en aquellos riesgos y controles que, si se gestionan correctamente, mejoran la probabilidad de que la organización alcance sus objetivos. Es fácil dedicar mucho tiempo a una evaluación de riesgos, en particular a la evaluación de probabilidades y consecuencias. Para facilitar una toma de decisiones eficiente sobre la gestión de riesgos, puede ser suficiente utilizar estimaciones iniciales y aproximadas de probabilidad y consecuencias.

7.3.2 Evaluación de las posibles consecuencias

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.2 d) 1).

Entrada: Una lista de los escenarios de eventos o riesgos relevantes identificados, incluyendo la identificación de las fuentes de riesgo, los procesos de negocio, los objetivos de negocio y los criterios de consecuencias. Además, se incluyen listas de todos los controles existentes, su eficacia, implementación y estado de uso.

ISO/IEC 27005:2022(E)

Acción: Se deben identificar y evaluar las consecuencias resultantes de no preservar adecuadamente la confidencialidad, integridad o disponibilidad de la información.

Desencadenante: La evaluación de las consecuencias se hace necesaria cuando:

- no se ha hecho antes;
- se modifica la lista elaborada mediante “identificación de riesgos”;
- los propietarios de riesgos o las partes interesadas han cambiado las unidades en las que desean que se expresen las consecuencias especificado; o
- se determinan cambios en el alcance o contexto que afectan las consecuencias.

Salida: Una lista de consecuencias potenciales relacionadas con escenarios de riesgo con sus consecuencias relacionadas con activos o eventos, dependiendo del enfoque aplicado.

Guía de implementación: _____

No preservar adecuadamente la seguridad de la información puede conllevar la pérdida de su confidencialidad, integridad o disponibilidad. Esta pérdida puede tener consecuencias adicionales para la organización y sus objetivos. El análisis de consecuencias puede realizarse de abajo a arriba, a partir de las consecuencias para la seguridad de la información, considerando qué podría ocurrir si se pierde la confidencialidad, integridad o disponibilidad de la información en cuestión. Normalmente, el responsable del riesgo puede estimar las consecuencias si se produce el evento. Se deben considerar los siguientes elementos:

- estimación (o medición basada en la experiencia) de las pérdidas (de tiempo o de datos) debidas al evento como resultado de la interrupción o perturbación de las operaciones;
- estimación/percepción de la gravedad de la consecuencia (por ejemplo, expresada en dinero);
- costos de recuperación dependiendo de si la recuperación se puede realizar internamente (por el equipo propietario del riesgo) o si es necesario llamar a una entidad externa.

7.3.3 Evaluación de la probabilidad

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.2 d) 2).

Entrada: Una lista de los escenarios de eventos o riesgos relevantes identificados, incluyendo la identificación de las fuentes de riesgo, los procesos de negocio, los objetivos de negocio y los criterios de probabilidad. Además, se incluyen listas de todos los controles existentes, su eficacia, implementación y estado de uso.

Acción: La probabilidad de ocurrencia de escenarios posibles o reales debe evaluarse y expresarse utilizando criterios de probabilidad establecidos.

Desencadenante: Junto con la consecuencia, evaluar la probabilidad es una actividad clave del proceso de evaluación de riesgos a la hora de determinar el nivel de riesgo.

La evaluación de la probabilidad se hace necesaria cuando:

- no se ha hecho antes;
- se determinen cambios en el alcance o contexto que puedan afectar la probabilidad;
- se descubren vulnerabilidades en los controles implementados;
- las pruebas/auditorías de eficacia del control dan lugar a resultados inesperados;
- se descubren cambios en el entorno de amenazas (por ejemplo, nuevos actores/fuentes de amenazas).

Salida: Una lista de eventos o escenarios de riesgo complementados con las probabilidades de que estos ocurran.

Guía de implementación: _____

Tras identificar los escenarios de riesgo, es necesario analizar la probabilidad de ocurrencia de cada escenario y sus consecuencias, mediante técnicas de análisis cualitativas o cuantitativas. Evaluar la probabilidad no siempre es fácil y debe expresarse de diferentes maneras. Esto debe tener en cuenta la frecuencia con la que se producen las fuentes de riesgo o la facilidad con la que algunas de ellas (por ejemplo, las vulnerabilidades) pueden explotarse, considerando:

- experiencia y estadísticas aplicables sobre la probabilidad de la fuente de riesgo;
- para fuentes de riesgo deliberadas: el grado de motivación [por ejemplo, la viabilidad (costo/beneficio) del ataque] y las capacidades (por ejemplo, el nivel de habilidad de los posibles atacantes), que cambian con el tiempo, los recursos disponibles para los posibles atacantes y las influencias sobre los posibles atacantes, como los delitos graves, las organizaciones terroristas o la inteligencia extranjera, así como la percepción del atractivo y la vulnerabilidad de la información para un posible atacante;
- para fuentes de riesgo accidentales: factores geográficos (por ejemplo, proximidad a instalaciones o actividades peligrosas), la posibilidad de desastres naturales como fenómenos meteorológicos extremos, actividad volcánica, terremotos, inundaciones, tsunamis y factores que pueden influir en los errores humanos y el mal funcionamiento de los equipos;
- las debilidades conocidas y cualquier control compensatorio, tanto individual como en conjunto;
- los controles existentes y la eficacia con la que reducen las debilidades conocidas.

La estimación de la probabilidad es intrínsecamente incierta, no solo porque considera hechos que aún no han sucedido y, por lo tanto, no se conocen completamente, sino también porque la probabilidad es una medida estadística y no es directamente representativa de eventos individuales. Las tres fuentes básicas de incertidumbre en la evaluación son:

- la incertidumbre personal que se origina en el juicio del evaluador, que se deriva de la variabilidad en la heurística mental de la toma de decisiones;
- incertidumbre metodológica, que se deriva del uso de herramientas que inevitablemente modelan los acontecimientos de manera simplista;
- incertidumbre sistémica sobre el evento anticipado en sí, que se deriva de un conocimiento insuficiente (en particular, si la evidencia es limitada o la fuente de riesgo cambia con el tiempo).

Para aumentar la confiabilidad de la estimación de probabilidad, las organizaciones deberían considerar el uso de:

- a) evaluaciones en equipo en lugar de evaluaciones individuales;
- b) fuentes externas, como informes de violaciones de la seguridad de la información;
- c) escalas con rango y resolución apropiados al enfoque de la organización;
- d) categorías unívocas, como “una vez al año”, en lugar de “poco frecuente”.

Al evaluar la probabilidad de eventos, es importante reconocer la diferencia entre eventos independientes y dependientes. La probabilidad de eventos que dependen entre sí está condicionada por la relación entre ellos (por ejemplo, un segundo evento puede ser inevitable si ocurre un primero), por lo que no es necesario evaluar por separado sus probabilidades. La probabilidad de eventos independientes relevantes contribuye esencialmente a la probabilidad de una consecuencia a la que contribuyen.

EJEMPLO: La probabilidad de un ataque de denegación de servicio (DNS) en un servidor depende del panorama de amenazas actual y de la vulnerabilidad y accesibilidad del servidor. Sin embargo, la probabilidad de paquetes maliciosos puede ser del 100 % una vez iniciado el ataque, y su evaluación no ayuda a evaluar la probabilidad del DNS.

Para evitar una complejidad innecesaria en la evaluación, es importante identificar cualquier dependencia entre los eventos que contribuyen a un escenario de riesgo y, en primera instancia, evaluar las probabilidades de aquellos eventos que son independientes entre sí.

La probabilidad general de consecuencias empresariales de un evento de seguridad de la información generalmente depende de la probabilidad de varios eventos contribuyentes de menor nivel y sus consecuencias. En lugar de intentar estimar la probabilidad de consecuencias empresariales en una única evaluación general,

ISO/IEC 27005:2022(E)

Puede ser más válido comenzar agregando las probabilidades de los niveles inferiores evaluados individualmente. acontecimientos que contribuyen a ello.

7.3.4 Determinación de los niveles de riesgo

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.2 d) 3).

Entrada: Una lista de escenarios de riesgo con sus consecuencias relacionadas con activos o eventos y su probabilidad (cuantitativa o cualitativa).

Acción: El nivel de riesgo debe determinarse como una combinación de la probabilidad evaluada y las consecuencias evaluadas para todos los escenarios de riesgo relevantes.

Desencadenante: Determinar los niveles de riesgo se vuelve necesario si se quieren evaluar los riesgos de seguridad de la información.

Salida: Una lista de riesgos con valores de nivel asignados.

Guía de implementación: _____

El nivel de riesgo puede determinarse de diversas maneras. Generalmente, se determina combinando la probabilidad y las consecuencias evaluadas para todos los escenarios de riesgo relevantes. Los cálculos alternativos pueden incluir el valor del activo, así como la probabilidad y la consecuencia. Además, el cálculo no es necesariamente lineal; por ejemplo, puede ser la probabilidad al cuadrado combinada con la consecuencia. En cualquier caso, el nivel de riesgo debe determinarse utilizando los criterios establecidos en el [apartado 6.4.3.4](#).

7.4 Evaluación de los riesgos de seguridad de la información

7.4.1 Comparación de los resultados del análisis de riesgos con los criterios de riesgo

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.2 e) 1).

Entrada: Una lista de criterios de riesgo y riesgos con valores de nivel asignados.

Acción: El nivel de riesgos debe compararse con los criterios de evaluación de riesgos, en particular los criterios de aceptación de riesgos.

Desencadenante: Comparar los resultados del análisis de riesgos con los criterios de riesgo se hace necesario si se desea priorizar los riesgos de seguridad de la información para su tratamiento.

Resultado: Una lista de sugerencias para tomar decisiones sobre acciones adicionales respecto de la gestión de riesgos.

Guía de implementación: _____

Una vez identificados los riesgos y asignados los valores de probabilidad y gravedad de las consecuencias, las organizaciones deben aplicar sus criterios de aceptación de riesgos para determinar si pueden aceptarse. Si no pueden aceptarse, deben priorizarse para su tratamiento.

Para evaluar los riesgos, las organizaciones deben comparar los riesgos evaluados con los criterios de riesgo definidos durante el establecimiento del contexto.

Las decisiones de evaluación de riesgos deben basarse en la comparación del riesgo evaluado con los criterios de aceptación definidos, idealmente considerando el grado de confianza en la evaluación. En algunos casos, como la ocurrencia frecuente de eventos de consecuencias relativamente bajas, puede ser útil considerar su efecto acumulativo a lo largo de una escala temporal de interés, en lugar del riesgo de cada evento individualmente, ya que esto puede proporcionar una representación más realista de los riesgos generales.

Puede haber incertidumbre al definir el límite entre los riesgos que requieren tratamiento y los que no. En determinadas circunstancias, no siempre es adecuado utilizar un único nivel de riesgo aceptable que divida los riesgos que requieren tratamiento de los que no. En algunos casos,

Puede ser más eficaz incluir un elemento de flexibilidad en los criterios incorporando parámetros adicionales como el coste y la eficacia de los posibles controles.

Los niveles de riesgo pueden validarse mediante el consenso entre los responsables del riesgo y los especialistas empresariales y técnicos. Es importante que los responsables del riesgo comprendan bien los riesgos de los que son responsables, lo cual concuerda con los resultados de una evaluación objetiva. Por consiguiente, cualquier discrepancia entre los niveles de riesgo evaluados y los percibidos por los responsables del riesgo debe investigarse para determinar cuál se aproxima mejor a la realidad.

7.4.2 Priorizar los riesgos analizados para su tratamiento

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.2 e) 2).

Entrada: Una lista de los resultados de los riesgos comparados con los criterios de riesgo.

Acción: Los riesgos de la lista deben priorizarse para su tratamiento, considerando los niveles de riesgo evaluados.

Desencadenante: Priorizar los riesgos analizados para su tratamiento se hace necesario si se quieren tratar los riesgos de seguridad de la información.

Resultado: Una lista de riesgos priorizados con escenarios de riesgo que conducen a esos riesgos.

Guía de implementación: _____

La evaluación de riesgos utiliza la comprensión del riesgo obtenida mediante el análisis de riesgos para formular propuestas que permitan decidir el siguiente paso. Estas deben referirse a:

— si se requiere un tratamiento de riesgo;

— prioridades para el tratamiento de riesgos considerando los niveles de riesgos evaluados.

Los criterios de riesgo utilizados para priorizar los riesgos deben considerar los objetivos de la organización, los requisitos contractuales, legales y reglamentarios, y las opiniones de las partes interesadas pertinentes. La priorización, tal como se realiza en la actividad de evaluación de riesgos, se basa principalmente en los criterios de aceptación.

8 Proceso de tratamiento de riesgos de seguridad de la información

8.1 General

La entrada del tratamiento de riesgos de seguridad de la información se basa en los resultados del proceso de evaluación de riesgos en forma de un conjunto priorizado de riesgos a tratar, en función de criterios de riesgo.

El resultado de este proceso es un conjunto de controles de seguridad de la información necesarios [véase ISO/IEC 27001:2022, 6.1.3 b)] que deben implementarse o mejorarse entre sí, de acuerdo con el plan de tratamiento de riesgos [véase ISO/IEC 27001:2022, 6.1.3 e)]. Implementado de esta manera, la eficacia del plan de tratamiento de riesgos reside en modificar el riesgo de seguridad de la información que enfrenta la organización para que cumpla con los criterios de aceptación de la organización.

8.2 Selección de opciones adecuadas para el tratamiento de riesgos de seguridad de la información

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.3 a).

Entrada: Una lista de riesgos priorizados con escenarios de eventos o riesgos que conducen a esos riesgos.

Acción: Se deben elegir opciones de tratamiento del riesgo.

Desencadenante: Seleccionar opciones adecuadas para el tratamiento de riesgos de seguridad de la información se vuelve necesario si no existe un plan de tratamiento de riesgos o si el plan está incompleto.

Resultado: Una lista de riesgos priorizados con las opciones de tratamiento de riesgos seleccionadas.

ISO/IEC 27005:2022(E)

Guía de implementación:

Varias opciones para el tratamiento del riesgo incluyen:

- evitar el riesgo, al decidir no iniciar o continuar con la actividad que genera el riesgo;
- modificación del riesgo, modificando la probabilidad de que se produzca un acontecimiento o una consecuencia o modificando la gravedad de la consecuencia;
- retención de riesgos, mediante elección informada;
- compartir el riesgo, dividiendo las responsabilidades con otras partes, ya sea interna o externamente (por ejemplo, compartiendo las consecuencias a través de un seguro);

EJEMPLO 1 Un ejemplo de prevención de riesgos es una oficina ubicada en una zona inundable, donde existe la posibilidad de una inundación y los consiguientes daños a la oficina, así como restricciones en la disponibilidad y/o el acceso a la misma. Los controles físicos pertinentes pueden resultar insuficientes para reducir este riesgo; en cuyo caso, la prevención de riesgos puede ser la mejor opción disponible. Esto puede implicar el cierre o la suspensión de la actividad de dicha oficina.

EJEMPLO 2 Otro ejemplo de evitación de riesgos es optar por no recopilar cierta información de individuos de modo que no sea necesario que la organización gestione, almacene y transmita la información en sus sistemas de información.

En el caso de compartir riesgos, se requiere al menos un control para modificar la probabilidad o consecuencia, pero la organización delega la responsabilidad de implementar el control a otra parte.

Las opciones de tratamiento de riesgos deben seleccionarse en función del resultado de la evaluación de riesgos, los costos previstos para su implementación y los beneficios esperados de estas opciones, tanto individualmente como en el contexto de otros controles. El tratamiento de riesgos debe priorizarse según los niveles de riesgo definidos, las limitaciones de tiempo y la secuencia necesaria de implementación, y los resultados de la evaluación de riesgos establecidos en [el apartado 7.4](#). Al elegir la opción, se puede considerar cómo perciben las [partes](#) afectadas un riesgo específico y las formas más adecuadas de comunicárselo.

8.3 Determinar todos los controles necesarios para implementar las opciones de tratamiento de riesgos de seguridad de la información

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.3 b).

Entrada: Una lista de riesgos priorizados con las opciones de tratamiento de riesgos seleccionadas.

Acción: Determinar todos los controles, de los conjuntos de controles elegidos según se seleccionen de una fuente apropiada, que son necesarios para tratar los riesgos según las opciones de tratamiento de riesgos elegidas, como modificar, retener, evitar o compartir los riesgos.

Desencadenante: Conformidad con el SGSI; gestión de riesgos de seguridad de la información.

Salida: Todos los controles necesarios.

Guía de implementación:

Se debe prestar especial atención a la determinación de los controles necesarios. Se debe verificar cada control para determinar si es necesario, preguntando:

- qué efecto tiene este control sobre la probabilidad o consecuencia de este riesgo;
- de qué manera el control mantiene el nivel de riesgo.

Sólo los controles que tengan un efecto más que insignificante sobre el riesgo deberían designarse como “necesarios”. Se deben aplicar uno o más controles a cada riesgo que se evalúe que requiere tratamiento.

Existen numerosas fuentes de conjuntos de controles. Se pueden encontrar en la norma ISO/IEC 27001:2022, Anexo A, en códigos de prácticas sectoriales (p. ej., ISO/IEC 27017) y en otros conjuntos de controles nacionales, regionales e industriales. Una organización también puede determinar uno o más controles personalizados (véase ISO/IEC 27003).

Si se define un control personalizado, su redacción debe describir con precisión y exactitud qué es y cómo funciona. Según corresponda, esta redacción puede incluir aspectos como:

- ¿Es un control documentado?
- quién posee el control;
- cómo se supervisa;
- cómo puede evidenciarse;
- cualquier excepción;
- frecuencia de funcionamiento del control;
- la tolerancia para el control;
- Si no es obvio, entonces la razón por la cual existe el control.

Si el control está fuera de la tolerancia, significa que no está funcionando con la suficiente eficacia para gestionar el riesgo identificado.

EJEMPLO 1: «Existe un proceso documentado de gestión de malware, propiedad del responsable de seguridad informática. Este proceso excluye los equipos Mac y se supervisa a través de la consola del proveedor, con informes de rendimiento que se envían semanalmente al director de informática».

Un enfoque tan detallado para la redacción de los controles puede ser útil si los controles personalizados también están destinados a apoyar a la organización en la elaboración de informes de aseguramiento del control. Sin embargo, es más importante que la redacción de los controles tenga significado para las personas de la organización y les ayude a tomar decisiones sobre la gestión de dichos controles y los riesgos asociados.

La determinación de los controles puede incluir nuevos controles aún no implementados o el uso de controles existentes en la organización. Sin embargo, un control ya implementado no debe incluirse automáticamente en la evaluación de riesgos porque:

- el control no es necesario para gestionar uno o más riesgos de seguridad de la información;
- puede ser un control que de alguna manera ayuda a gestionar uno o más riesgos de seguridad de la información pero que no es lo suficientemente eficaz para ser incluido en la evaluación de riesgos o gestionado por el SGSI, o;
- puede estar actualmente en funcionamiento por razones no relacionadas con la seguridad de la información (por ejemplo, calidad, eficiencia, eficacia o cumplimiento), o;
- está actualmente en funcionamiento pero desde una perspectiva de seguridad de la información se puede eliminar ya que no tiene suficiente efecto para justificar su condición continua como control esencial.

Si se utiliza un control para fines distintos a la mera gestión de riesgos de seguridad de la información, se debe tener cuidado de garantizar que el control se gestione para lograr los objetivos de seguridad de la información, así como los objetivos de seguridad no relacionados con la información.

EJEMPLO 2 CCTV interno para controlar la calidad del proceso de producción así como por razones de seguridad de la información (para protegerse del fraude).

Al determinar los controles a partir de un conjunto de controles existente (p. ej., ISO/IEC 27001:2022, Anexo A o una lista de controles específica del sector), la redacción del control debe ser acorde con lo necesario para gestionar el riesgo y reflejar con precisión qué es o debería ser el control. Si el enfoque general consiste en utilizar un conjunto de controles existente (p. ej., ISO/IEC 27001:2022, Anexo A o una lista de controles específica del sector) y este no contiene un control que describa con precisión el control necesario, se debe considerar la definición de un control personalizado que lo describa con precisión.

ISO/IEC 27005:2022(E)

Los controles se pueden clasificar en preventivos, detectivos y correctivos:

- a) control preventivo: un control que tiene como objetivo prevenir la ocurrencia de un problema de seguridad de la información. acontecimiento que puede dar lugar a la ocurrencia de una o más consecuencias;
- b) control de detección: un control que tiene como objetivo detectar la ocurrencia de una violación de seguridad de la información. evento;
- c) control correctivo: un control que tiene como objetivo limitar las consecuencias de un problema de seguridad de la información. evento.

El tipo de control describe si un control actúa, o pretende actuar, para prevenir o detectar un evento o reaccionar a sus consecuencias.

EJEMPLO 3 Una política de seguridad de la información es un control que mantiene el riesgo, pero el cumplimiento de la política tiene como objetivo reducir la probabilidad de que ocurra el riesgo y, por lo tanto, puede clasificarse como preventivo.

La utilidad de clasificar los controles como preventivos, detectivos y correctivos reside en su uso para garantizar que la elaboración de planes de tratamiento de riesgos sea resiliente ante fallos de control. Siempre que exista una combinación adecuada de controles preventivos, detectivos y correctivos:

- los controles de detección deberían mitigar el riesgo si los controles preventivos fallan;
- los controles correctivos deberían mitigar el riesgo si los controles de detección fallan;
- Los controles preventivos deberían reducir la probabilidad de que alguna vez sea necesario implementar controles correctivos. usado.

Al utilizar controles, las organizaciones deben determinar primero si es posible detectar la ocurrencia de un evento. De ser así, se deben implementar controles de detección. Si no es posible detectar un evento, los controles de detección pueden resultar ineficaces, sin posibilidad de determinar si un control preventivo está funcionando.

EJEMPLO 4 Si no está claro si una computadora se ha convertido en parte de una "botnet", no se puede saber si los controles que se utilizan para evitar que se convierta en parte de una botnet funcionan como se espera.

Los controles detectivescos pueden funcionar según sea necesario, pero aun así pueden resultar ineficaces.

EJEMPLO 5 Implementar sistemas de detección/prevención de intrusiones puede ser una forma efectiva de evitar que el malware atraviese la red, pero no sirven de nada si no hay un monitoreo de los sistemas/alertas para actuar en caso de que haya un brote que no esté contenido.

En general, los controles de detección resultan ineficaces cuando se pueden eludir o cuando su notificación no da lugar a las medidas adecuadas. A continuación, se deben considerar los controles correctivos. Si los controles de detección fallan, es probable que se produzcan una o más consecuencias indeseables.

La implementación de controles correctivos puede ayudar a limitar dichas consecuencias. Si bien estos controles entran en vigor después de la ocurrencia de la consecuencia, a menudo es necesario implementarlos con mucha antelación a la ocurrencia de cualquier evento.

EJEMPLO 6: El cifrado del disco duro no impide el robo de una computadora portátil ni los intentos posteriores de extraer los datos. Sin embargo, sí reduce la gravedad de las consecuencias de una divulgación. El control, por supuesto, debe implementarse antes del robo de la computadora portátil.

La categorización de los controles no es absoluta y depende del contexto en el que se utiliza un control. descrito.

EJEMPLO 7: La copia de seguridad no previene la ocurrencia de un evento que, de otro modo, resultaría en la pérdida de datos (por ejemplo, una rotura del cabezal de un disco duro o la pérdida de una computadora portátil), pero sí ayuda a reducir las consecuencias. Por lo tanto, algunas organizaciones pueden considerar esto como un control correctivo en lugar de preventivo. De igual manera, el cifrado no previene la pérdida de información, pero si el evento se describe como "datos personales revelados a un atacante", entonces el cifrado es un control preventivo, no correctivo.

El orden en que se organizan los controles que abordan los riesgos depende de diversos factores. Se pueden utilizar diversas técnicas. Es responsabilidad de los respectivos responsables de los riesgos determinar el equilibrio entre los costos de invertir en controles y asumir las consecuencias en caso de que los riesgos se materialicen.

La identificación de los controles existentes puede determinar que estos controles exceden las necesidades actuales. Un costo– Se debe realizar un análisis de beneficios antes de eliminar controles redundantes o innecesarios (especialmente si estos tienen altos costos de mantenimiento). Dado que los controles pueden influirse entre sí, eliminar controles redundantes puede reducir la seguridad general implementada. Los controles no deben incluirse en el tratamiento de riesgos a menos que sean necesarios para gestionar uno o más de los riesgos de seguridad de la información identificados.

Un control debe influir en la consecuencia o probabilidad de los riesgos de seguridad de la información identificados. Los controles no deben incluirse en el tratamiento de riesgos si operan por razones no relacionadas con la seguridad de la información.

Se debe prestar atención a los controles que se implementan pero que se sabe que tienen algunas debilidades.

Si la evaluación de todos los riesgos que gestiona un control con debilidades se encuentra dentro de los criterios de aceptación, no es necesario mejorar el control. Aunque el control no funcione con plena eficacia, no siempre es necesario mejorarlo para que sea plenamente efectivo. No debe asumirse que todos los controles deben funcionar con plena eficacia para que la organización gestione sus riesgos con éxito.

Es posible especificar que cada control individual tenga un nivel de tolerancia a fallos, por debajo del cual se puede considerar que no funciona con la eficacia suficiente para gestionar los riesgos identificados. Mientras el control funcione dentro de la tolerancia, no necesita ninguna mejora.

8.4 Comparación de los controles determinados con los de la norma ISO/IEC 27001:2022, Anexo A

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.3 c).

Entrada: Todos los controles necesarios (ver [8.3](#)).

Acción: Comparar todos los controles necesarios con los enumerados en ISO/IEC 27001:2022, Anexo A.

Desencadenante: La identificación de cualquier control faltante se vuelve necesaria si se formulan planes de tratamiento de riesgos.

Salida: Todos los controles aplicables al tratamiento del riesgo.

Guía de implementación: _____

La norma ISO/IEC 27001:2022, apartado 6.1.3 c), exige que una organización compare los controles que ha determinado como necesarios para implementar las opciones de tratamiento de riesgos elegidas con los controles enumerados en el Anexo A de la norma ISO/IEC 27001:2022. El objetivo de esta comprobación es verificar que no se hayan omitido controles necesarios en la evaluación de riesgos. Esta comprobación no se implementa para identificar controles omitidos de la norma ISO/IEC 27001:2022, Anexo A, en la evaluación de riesgos. Se trata de una comprobación para identificar cualquier control necesario faltante, de cualquier fuente, mediante la comparación de los controles con otras normas y listas de controles. Los controles omitidos identificados durante esta comprobación pueden ser específicos del sector, controles personalizados o de la norma ISO/IEC 27001:2022, Anexo A. Las directrices para determinar los controles en [el apartado 8.3](#)

Se debe tener en cuenta lo siguiente al considerar si se deben agregar controles faltantes a la evaluación de riesgos.

EJEMPLO Es importante que un control que ya está operando en la organización no se agregue automáticamente a la evaluación de riesgos sin una consideración adicional.

Es importante recordar que esta comparación de los controles se realiza mediante la evaluación de riesgos y no mediante la Declaración de Aplicabilidad. El principio consiste en examinar cada riesgo individualmente y comparar los controles considerados necesarios para cada riesgo con los controles de la norma ISO/IEC 27001:2022, Anexo A, para identificar si faltan controles necesarios para cada riesgo.

8.5 Elaboración de una declaración de aplicabilidad

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.3 d).

Entrada: Todos los controles aplicables al tratamiento del riesgo (ver [8.4](#)).

Acción: Elaborar una declaración de aplicabilidad.

ISO/IEC 27005:2022(E)

Desencadenante: Documentación de todos los controles necesarios, su justificación y estado de implementación.

Salida: Declaración de aplicabilidad.

Guía de implementación: _____

De acuerdo con la norma ISO/IEC 27001:2022, 6.1.3 d), la Declaración de Aplicabilidad (SOA) debe contener al menos:

- a) los controles necesarios;
- b) justificación de su inclusión;
- c) si se implementan o no;
- d) justificación de las exclusiones de controles de la norma ISO/IEC 27001:2022, Anexo A.

La SOA puede elaborarse fácilmente examinando la evaluación de riesgos para identificar los controles necesarios y el plan de tratamiento de riesgos para identificar aquellos que se planea implementar. Solo los controles identificados en la evaluación de riesgos pueden incluirse en la SOA. No se pueden agregar controles a la SOA independientemente de la evaluación de riesgos. Debe haber coherencia entre los controles necesarios para implementar las opciones de tratamiento de riesgos seleccionadas y la SOA. La SOA puede indicar que la justificación para la inclusión de un control es la misma para todos los controles y que se han identificado en la evaluación de riesgos como necesarios para tratar uno o más riesgos a un nivel aceptable. No se necesita ninguna justificación adicional para la inclusión de un control para ninguno de los controles. El estado de implementación de todos los controles contenidos en la SOA puede indicarse como "implementado", "parcialmente implementado" o "no implementado". Esto puede ser individualmente para cada control o como una declaración general.

EJEMPLO: La SOA contiene la declaración: «Se han implementado todos los controles». No se requiere análisis ni información adicional para completar la SOA.

8.6 Plan de tratamiento de riesgos de seguridad de la información

8.6.1 Formulación del plan de tratamiento de riesgos

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.3 e).

Entrada: Resultados de las evaluaciones de riesgos.

Acción: Formular plan de tratamiento de riesgos.

Desencadenante: Necesidad de la organización de tratar los riesgos.

Salida: Plan de tratamiento de riesgos.

Guía de implementación: _____

El propósito de esta actividad es crear uno o más planes para tratar conjuntos específicos de riesgos que se encuentran en la lista de riesgos priorizados (véase [la Cláusula 7](#)). Un plan de tratamiento de riesgos es un plan para modificar el riesgo de manera que cumpla con los criterios de aceptación de riesgos de la organización (véase [6.4.2](#)). Existen dos posibles interpretaciones del término "plan" en el contexto del tratamiento de riesgos. La primera es un plan de proyecto, es decir, un plan para implementar los controles necesarios de la organización. La segunda es un plan de diseño, es decir, el plan que no solo identifica los controles necesarios, sino que también describe cómo los controles interactúan con su entorno y entre sí para modificar los riesgos. En la práctica, se pueden utilizar ambos.

Una vez establecidos los controles, el plan del proyecto deja de tener valor salvo como registro histórico, mientras que el plan de diseño sigue siendo útil.

Todo riesgo que requiera tratamiento debe incluirse en uno de los planes de tratamiento de riesgos. Una organización puede optar por varios planes de tratamiento de riesgos, que en conjunto implementan todos los aspectos necesarios. Estos pueden organizarse según la ubicación de la información (por ejemplo, un plan...)

para el centro de datos, otro para la informática móvil, etc.), por activo (por ejemplo, diferentes planes para diferentes clasificaciones de activos) o por eventos (como los utilizados al evaluar el riesgo utilizando el método basado en eventos).

Al crear el plan de tratamiento de riesgos, las organizaciones deben considerar lo siguiente:

- prioridades en relación con el nivel de riesgo y la urgencia del tratamiento;
- si existen diferentes tipos de controles (preventivos, detectivos, correctivos) o su composición aplicable;
- si es necesario esperar a que se resuelva un control antes de comenzar a implementar uno nuevo el mismo activo;
- si existe un retraso entre el momento en que se implementa el control y el momento en que es plenamente efectivo y operativo.

Para cada riesgo tratado, el plan de tratamiento debe incluir la siguiente información:

- la justificación de la selección de las opciones de tratamiento, incluidos los beneficios esperados que se obtendrán;
- aquellos que son responsables de aprobar e implementar el plan;
- las acciones propuestas;
- los recursos necesarios, incluidas las contingencias;
- los indicadores de rendimiento;
- las restricciones;
- la presentación de informes y el seguimiento necesarios;
- cuándo se espera que se realicen y completen las acciones;
- estado de implementación.

Las acciones del plan de tratamiento de riesgos deben priorizarse según el nivel de riesgo y la urgencia del tratamiento. Cuanto mayor sea el nivel de riesgo y, en algunos casos, la frecuencia de ocurrencia, más pronto se implementará el control.

Para cada riesgo enumerado dentro del plan de tratamiento de riesgos, se debe realizar un seguimiento de la información de implementación detallada, que puede incluir, entre otros:

- nombres de los propietarios de los riesgos y de las personas responsables de su implementación;
- fechas o plazos de ejecución;
- actividades de control planificadas para probar el resultado de la implementación;
- estado de implementación;
- nivel de costos (inversión, operación).

8.6.2 Aprobación por parte de los propietarios de riesgos

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.3 f).

Entrada: Plan(es) de tratamiento de riesgos.

Acción: Aprobación de los planes de tratamiento de riesgos por parte de los propietarios de los riesgos.

Desencadenante: La necesidad de que se aprueben los planes de tratamiento de riesgos.

Resultado: Plan(es) de tratamiento de riesgos aprobado(s).

ISO/IEC 27005:2022(E)

Guía de implementación:

El plan de tratamiento de riesgos de seguridad de la información debe ser aprobado por los responsables de los riesgos una vez formulado. Estos también deben decidir sobre la aceptación de los riesgos residuales de seguridad de la información. Esta decisión debe basarse en criterios definidos de aceptación de riesgos.

Los resultados de la evaluación de riesgos, el plan de tratamiento de riesgos y los riesgos restantes deben ser comprensibles para los propietarios de los riesgos para que puedan cumplir con sus responsabilidades adecuadamente.

8.6.3 Aceptación de los riesgos residuales de seguridad de la información

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 6.1.3 f).

Entrada: Planes de tratamiento de riesgos aprobados y criterios de aceptación de riesgos.

Acción: Determinar si los riesgos residuales son aceptables.

Desencadenante: La necesidad de que la organización decida retener los riesgos residuales.

Salida: Riesgos residuales aceptados.

Guía de implementación:

Para determinar los riesgos residuales, los planes de tratamiento de riesgos deben integrarse en la evaluación de seguimiento de la probabilidad y las consecuencias residuales. Los controles propuestos, descritos en los planes de tratamiento de riesgos, y su eficacia deben considerarse considerando si reducirán la probabilidad, las consecuencias o ambas, y si el nivel de riesgos residuales se asigna a los riesgos. El responsable del riesgo considera entonces el nivel de riesgos residuales para determinar si son aceptables.

Los planes de tratamiento de riesgos deben describir cómo se tratarán los riesgos evaluados para cumplir con los criterios de aceptación de riesgos.

En algunos casos, el nivel de riesgo residual no siempre cumple con los criterios de aceptación del riesgo, porque los criterios que se aplican no tienen en cuenta las circunstancias prevalecientes.

EJEMPLO Se puede argumentar que es necesario retener los riesgos porque los beneficios que acompañan a los riesgos son una oportunidad de negocio importante o porque el costo de modificarlos es demasiado alto.

Sin embargo, no siempre es posible revisar los criterios de aceptación de riesgos de manera oportuna. En tales casos, los responsables de los riesgos pueden retener los riesgos que no cumplen con los criterios de aceptación habituales. De ser necesario, el responsable de los riesgos debe comentar explícitamente sobre los riesgos e incluir una justificación de la decisión de anular los criterios de aceptación habituales.

La aceptación de riesgos puede implicar un proceso para obtener la aprobación de los tratamientos antes de tomar la decisión final. Es importante que los responsables del riesgo revisen y aprueben los planes de tratamiento propuestos y los riesgos residuales resultantes, y registren cualquier condición asociada a dicha aprobación. Dependiendo del proceso de evaluación de riesgos y los criterios de aceptación, esto puede requerir que un gerente con mayor autoridad que el responsable del riesgo apruebe la aceptación.

Implementar un plan para abordar los riesgos evaluados puede llevar tiempo. Los criterios de riesgo permiten que los niveles de riesgo superen un umbral deseado en una medida definida si existe un plan para reducirlo en un plazo aceptable. Las decisiones sobre la aceptación del riesgo pueden tener en cuenta los plazos de los planes de tratamiento y si el progreso de la implementación del tratamiento se ajusta a lo planificado.

Algunos riesgos pueden variar con el tiempo (independientemente de si este cambio se debe a la implementación de un plan de tratamiento de riesgos). Los criterios de aceptación de riesgos pueden tener esto en cuenta y establecer umbrales de aceptación que dependen del tiempo que una organización puede estar expuesta a un riesgo evaluado.

9 Operación

9.1 Realización del proceso de evaluación de riesgos de seguridad de la información

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 8.2.

Entrada: Documentos sobre el proceso de evaluación de riesgos de seguridad de la información, incluyendo la evaluación de riesgos y los criterios de aceptación de riesgos.

Acción: El proceso de evaluación de riesgos debe realizarse de acuerdo con [la Cláusula 7](#).

Desencadenante: Necesidad de la organización de evaluar los riesgos, a intervalos planificados o en función de eventos.

Salida: Riesgos evaluados.

Guía de implementación: _____

El proceso de evaluación de riesgos de seguridad de la información, definido y aplicado en la norma ISO/IEC 27001:2022, apartado 6.1, debe integrarse en las operaciones de la organización y realizarse a intervalos planificados o cuando se propongan o se produzcan cambios significativos. El proceso de evaluación de riesgos de seguridad de la información debe tener en cuenta los criterios establecidos en la norma ISO/IEC 27001:2022, apartado 6.1.2 a). La frecuencia con la que se realiza la evaluación de riesgos debe ser adecuada al SGSI. Cuando se produce un cambio significativo en el SGSI (o su contexto) o en el panorama de amenazas (p. ej., un nuevo tipo de ataque a la seguridad de la información), la organización debe determinar si este cambio requiere una evaluación de riesgos de seguridad de la información adicional.

Al elaborar planes para evaluaciones de riesgos de rutina, las organizaciones deben tener en cuenta cualquier calendario que se aplique a sus procesos comerciales generales y los ciclos presupuestarios asociados.

EJEMPLO: Si existe un ciclo presupuestario anual, la organización podría estar obligada a presentar solicitudes de financiación en un momento determinado del año. Los fondos se conceden (reducen o deniegan) posteriormente.

Si se involucran los procesos de adquisición, puede haber otro ciclo presupuestario antes de implementar las recomendaciones para el tratamiento de riesgos y evaluar su eficacia antes de la siguiente evaluación de riesgos rutinaria. En tales casos, las evaluaciones de riesgos deben programarse:

- a) formular sus recomendaciones sobre el tratamiento de riesgos a tiempo para la solicitud de financiación;
- b) ser reevaluados en función de los resultados de las asignaciones presupuestarias;
- c) realizar la siguiente evaluación de rutina, una vez implementadas las recomendaciones, después de cualquier actividad de adquisición.

9.2 Realización del proceso de tratamiento de riesgos de seguridad de la información

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 8.3.

Entrada: Riesgo(s) evaluado(s).

Acción: El proceso de tratamiento de riesgos deberá realizarse de acuerdo con [la Cláusula 8](#).

Desencadenante: Necesidad de la organización de tratar los riesgos, a intervalos planificados o en función de eventos.

Salida: Riesgos residuales retenidos o aceptados.

Guía de implementación: _____

La norma ISO/IEC 27001:2022, apartado 8.3, especifica los requisitos que las organizaciones deben cumplir para implementar sus planes de tratamiento de riesgos. Las consideraciones incluidas en el [apartado 8.6](#) también son relevantes para esta subcláusula.

ISO/IEC 27005:2022(E)

10 Aprovechamiento de los procesos relacionados del SGSI

10.1 Contexto de la organización

NOTA Esta subcláusula se relaciona con la norma ISO/IEC 27001:2022, Cláusula 4.

Entrada: Información sobre la organización, su contexto interno y externo.

Acción: Se deben considerar todos los datos relevantes para identificar y describir los problemas internos y externos que influyen en la gestión de riesgos de seguridad de la información y los requisitos de las partes interesadas.

Desencadenante: ISO/IEC 27001:2022 especifica los requisitos para que dicha información pueda establecer objetivos de seguridad de la información.

Resultado: Cuestiones internas y externas relacionadas con los riesgos que influyen en la gestión de riesgos de seguridad de la información.

Guía de implementación: _____

La organización debe tener una comprensión general (p. ej., estratégica) de los aspectos importantes que pueden afectar al SGSI, ya sea positiva o negativamente. Además, debe conocer el contexto interno y externo relevante para su propósito y que afecta su capacidad para lograr el resultado previsto de su SGSI.

Los resultados esperados deben garantizar la preservación de la confidencialidad, integridad y disponibilidad de la información mediante la aplicación del proceso de gestión de riesgos y sabiendo qué riesgos se gestionan adecuadamente.

Para identificar los riesgos de forma fiable, la organización debe comprender con suficiente detalle las circunstancias en las que opera. Esto significa que debe recopilar información sobre su contexto interno y externo, sus partes interesadas y sus requisitos (véase ISO/IEC 27001:2022, 4.1 y 4.2). Esta información debe recopilarse antes de que la organización intente evaluar sus riesgos de seguridad de la información, o cualquier otro riesgo que pueda afectar al resultado previsto del SGSI (véase ISO/IEC 27001:2022, 6.1.1).

La organización debe considerar todas las fuentes de riesgo internas y externas. Es fundamental que comprenda a las partes interesadas que se oponen a la organización y sus intereses.

EJEMPLO 1 Un ejemplo de una parte interesada con intereses opuestos a los objetivos de la organización es el atacante. El atacante desea una organización con un nivel de seguridad bajo. La organización tiene en cuenta el interés de esta parte al tener lo contrario (un nivel de seguridad alto), es decir, considera posibles conflictos con los objetivos del SGSI. La organización garantiza, mediante controles eficaces de seguridad de la información, que estos intereses no se cumplan.

Las interfaces con servicios o actividades que no están completamente dentro del alcance del SGSI deben considerarse en la evaluación de riesgos de seguridad de la información de la organización.

EJEMPLO 2 Un ejemplo de tal situación es compartir activos (por ejemplo, instalaciones, sistemas de TI y bases de datos) con otras organizaciones o la externalización de una función empresarial.

La forma en que se consideran otros factores relevantes que influyen en la seguridad de la información depende de los métodos de identificación y análisis de riesgos que elija la organización.

Los objetivos de seguridad de la información de la organización (véase ISO/IEC 27001:2022, 6.2) pueden limitar los criterios de aceptación de riesgos (p. ej., el nivel aceptable de riesgo puede depender de las posibles recompensas asociadas a las diferentes actividades de la empresa). Además, la política de seguridad de la información puede limitar el tratamiento de riesgos (p. ej., ciertas opciones de tratamiento de riesgos pueden quedar excluidas de dicha política).

10.2 Liderazgo y compromiso

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 5.1.

Entrada: Información sobre los resultados de la evaluación de riesgos de seguridad de la información o los resultados del tratamiento de riesgos de seguridad de la información que requieren aprobación o respaldo.

Acción: El nivel apropiado de gestión debe considerar los resultados relacionados con los riesgos de seguridad de la información, para decidir o aprobar acciones futuras.

Desencadenante: La norma ISO/IEC 27001 exige que haya un nivel adecuado de gestión involucrado en todas las actividades relacionadas con los riesgos de seguridad de la información.

Resultado: Decisiones o avales relacionados con riesgos de seguridad de la información.

Guía de implementación: _____

La alta dirección es responsable de gestionar los riesgos y debe liderar e impulsar las evaluaciones de riesgos, incluyendo:

- garantizar que se asignen los recursos necesarios para la gestión del riesgo;
- asignar autoridad, responsabilidad y rendición de cuentas en los niveles apropiados dentro de la organización en lo que se refiere a la gestión de riesgos;
- comunicarse con las partes interesadas apropiadas.

10.3 Comunicación y consulta

NOTA 1 Esta subcláusula se relaciona con ISO/IEC 27001:2022, 7.4.

NOTA 2 La norma ISO/IEC 27001 se refiere directamente a la parte de comunicación de esta actividad.

Entrada: Información sobre los riesgos, sus causas, consecuencias y su probabilidad identificados a través de los procesos de gestión de riesgos.

Acción: La información sobre los riesgos, sus causas, consecuencias, su probabilidad y los controles que se están adoptando para tratarlos debe comunicarse a las partes interesadas externas e internas, u obtenerse de ellas.

Desencadenante: ISO/IEC 27001 requiere dicha comunicación.

Resultado: Percepciones de las partes interesadas relevantes y comprensión continua del proceso y los resultados de la gestión de riesgos de seguridad de la información de la organización.

Guía de implementación: _____

La actividad de comunicación y consulta busca alcanzar un acuerdo sobre cómo gestionar los riesgos mediante el intercambio de información sobre los riesgos con los responsables de los mismos y otras partes interesadas pertinentes. Esta información incluye, entre otros aspectos, la existencia, la naturaleza, la forma, la probabilidad, las consecuencias, la importancia, el tratamiento y la aceptación de los riesgos.

La norma ISO/IEC 27001:2022, 6.1.2 c) 2), requiere que se identifiquen los propietarios de los riesgos de seguridad de la información.

La responsabilidad del riesgo puede confundirse u ocultarse deliberadamente. Incluso cuando se puede identificar a los responsables del riesgo, estos pueden ser reacios a reconocer su responsabilidad por los riesgos que les corresponden, y lograr su participación en el proceso de gestión de riesgos puede resultar difícil. Debe existir un procedimiento de comunicación definido para informar a las personas implicadas sobre la responsabilidad del riesgo.

La norma ISO/IEC 27001:2022, 6.1.3 f), exige que los responsables de los riesgos aprueben el plan o los planes de tratamiento de riesgos y decidan sobre la aceptación de los riesgos residuales. La comunicación entre los responsables de los riesgos y el personal responsable de la implementación del SGSI es una actividad importante. Debe existir un acuerdo sobre cómo gestionar los riesgos mediante el intercambio de información con los responsables de los riesgos, y posiblemente con otras partes interesadas y responsables de la toma de decisiones. Esta información incluye, entre otros aspectos, la existencia, la naturaleza, la forma, la probabilidad, la importancia, el tratamiento y la aceptación de los riesgos. La comunicación debe ser bidireccional.

ISO/IEC 27005:2022(E)

Dependiendo de la naturaleza y la sensibilidad del riesgo, puede ser necesario limitar la información sobre los riesgos, su evaluación y tratamiento, según la necesidad de conocer, a los responsables de identificarlos, evaluarlos y gestionarlos. La comunicación de riesgos debe controlarse según la necesidad de conocer, teniendo en cuenta el nivel de detalle requerido por las diferentes partes interesadas, en consulta con los propietarios o posibles propietarios de los riesgos, con el fin de evitar la divulgación de los riesgos más sensibles y sus debilidades conocidas asociadas.

La percepción del riesgo puede variar debido a las diferencias en los supuestos, conceptos, necesidades, problemas e inquietudes de las partes interesadas en relación con el riesgo o los temas en discusión. Es probable que las partes interesadas juzguen la aceptación del riesgo basándose en su percepción del mismo.

Esto es especialmente importante para garantizar que las percepciones de los riesgos de las partes interesadas, así como sus percepciones de los beneficios, puedan identificarse y documentarse, y que las razones subyacentes puedan entenderse y abordarse claramente.

La comunicación y la consulta sobre riesgos pueden mejorar la participación de las partes interesadas en las acciones realizadas y hacer que las partes interesadas pertinentes se responsabilicen de las decisiones y los resultados. A medida que se desarrollan los criterios y se seleccionan los métodos de evaluación de riesgos, la comunicación y la consulta con las partes interesadas también pueden mejorar su apropiación de los resultados. Es menos probable que las partes interesadas cuestionen los resultados de los procesos que han contribuido a diseñar. Como resultado, suele aumentar la probabilidad de que acepten los hallazgos y apoyen los planes de acción. Cuando las partes interesadas son gestores, esto puede generar compromiso para alcanzar los objetivos de gestión de riesgos y proporcionar los recursos necesarios.

La comunicación de riesgos debe realizarse con el fin de:

- garantizar el resultado de la gestión de riesgos de la organización;
- recopilar información sobre riesgos;
- compartir los resultados de la evaluación de riesgos y presentar el plan de tratamiento de riesgos;
- evitar o reducir tanto la ocurrencia como las consecuencias de las violaciones de seguridad de la información debido a la falta de entendimiento mutuo entre los propietarios de los riesgos y las partes interesadas;
- apoyar a los propietarios de riesgos;
- adquirir nuevos conocimientos en seguridad de la información;
- coordinar con otras partes y planificar respuestas para reducir las consecuencias de cualquier incidente;
- dar un sentido de responsabilidad a los propietarios de riesgos y otras partes con un interés legítimo en riesgo;
- mejorar la concienciación.

Una organización debe desarrollar planes de comunicación de riesgos tanto para las operaciones normales como para emergencias. La comunicación de riesgos y la consulta deben realizarse de forma continua.

La coordinación entre los principales propietarios de riesgos y las partes interesadas relevantes se puede lograr mediante la formación de un comité en el que pueda tener lugar el debate sobre los riesgos, su priorización, tratamiento apropiado y aceptación.

Las comunicaciones de riesgo pueden enviarse voluntariamente a terceros externos para permitir una mejor gestión de riesgos o una mejor coordinación o concientización sobre la respuesta y también pueden ser requeridas por los reguladores o socios comerciales en determinadas circunstancias.

Es importante cooperar con la unidad de relaciones públicas o comunicación correspondiente de la organización para coordinar todas las tareas relacionadas con la comunicación de riesgos. Esto es crucial en caso de que se active la comunicación de crisis, por ejemplo, en respuesta a incidentes específicos.

10.4 Información documentada

10.4.1 General

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 7.5.

La norma ISO/IEC 27001 especifica los requisitos para que las organizaciones conserven información documentada sobre el proceso de evaluación de riesgos (véase ISO/IEC 27001:2022, 6.1.2) y los resultados (véase ISO/IEC 27001:2022, 8.2); el proceso de tratamiento de riesgos (ISO/IEC 27001:2022, 6.1.3) y los resultados (ISO/IEC 27001:2022, 8.3).

10.4.2 Información documentada sobre los procesos

Entrada: Conocimiento sobre los procesos de evaluación y tratamiento de riesgos de seguridad de la información de acuerdo a [las Cláusulas 7 y 8](#), definidos por la organización.

Acción: La información sobre los procesos de evaluación y tratamiento de riesgos de seguridad de la información debe documentarse y conservarse.

Desencadenante: ISO/IEC 27001 requiere información documentada sobre los procesos de evaluación y tratamiento de riesgos de seguridad de la información.

Salida: Información documentada requerida por las partes interesadas (por ejemplo, organismo de certificación) o determinada por la organización como necesaria para la eficacia del proceso de evaluación de riesgos de seguridad de la información o del proceso de tratamiento de riesgos de seguridad de la información.

Guía de implementación: _____

La información documentada sobre el proceso de evaluación de riesgos de seguridad de la información debe contener:

- a) una definición de los criterios de riesgo (incluidos los criterios de aceptación del riesgo y los criterios para su ejecución) evaluaciones de riesgos de seguridad de la información);
- b) razonamiento sobre la consistencia, validez y comparabilidad de los resultados;
- c) una descripción del método de identificación de riesgos (incluida la identificación de los propietarios de los riesgos);
- d) una descripción del método para analizar los riesgos de seguridad de la información (incluida la evaluación de las consecuencias potenciales, la probabilidad realista y el nivel de riesgo resultante);
- e) una descripción del método para comparar los resultados con los criterios de riesgo y la priorización de riesgos para el tratamiento del riesgo.

La información documentada sobre el proceso de tratamiento de riesgos de seguridad de la información debe contener descripciones de:

- el método para seleccionar opciones apropiadas de tratamiento de riesgos de seguridad de la información;
- el método para determinar los controles necesarios;
- cómo se utiliza la norma ISO/IEC 27001:2022, Anexo A, para determinar que no se han aplicado los controles necesarios pasado por alto inadvertidamente;
- cómo se elaboran los planes de tratamiento de riesgos;
- cómo se obtiene la aprobación de los propietarios de riesgos.

10.4.3 Información documentada sobre los resultados

Entrada: Los resultados de la evaluación y tratamiento de riesgos de seguridad de la información.

Acción: La información sobre la evaluación de riesgos de seguridad de la información y los resultados del tratamiento deben ser documentado y conservado.

ISO/IEC 27005:2022(E)

Desencadenante: ISO/IEC 27001 requiere información documentada sobre el riesgo de seguridad de la información Resultados de la evaluación y el tratamiento.

Resultado: Información documentada sobre los resultados de la evaluación y el tratamiento de riesgos de seguridad de la información.

Guía de implementación: _____

Dado que las organizaciones deben realizar evaluaciones de riesgos a intervalos planificados o cuando se proponen o se producen cambios significativos, debe existir al menos evidencia de un cronograma y de que las evaluaciones de riesgos se realizan de acuerdo con dicho cronograma. Si se propone o se ha producido un cambio, debe existir evidencia de la realización de una evaluación de riesgos asociada. De lo contrario, la organización debe explicar por qué el cambio es significativo o no.

La información documentada sobre los resultados de la evaluación de riesgos de seguridad de la información debe contener:

- a) los riesgos identificados, sus consecuencias y probabilidad;
- b) la identidad del propietario o propietarios del riesgo;
- c) los resultados de la aplicación de los criterios de aceptación de riesgos;
- d) la prioridad en el tratamiento del riesgo.

También se recomienda registrar la justificación de las decisiones sobre riesgos, con el fin de aprender de los errores en casos individuales y facilitar la mejora continua.

La información documentada sobre los resultados del tratamiento de riesgos de seguridad de la información debe contener:

- identificación de los controles necesarios;
- cuando sea apropiado y esté disponible, evidencia de que estos controles necesarios actúan para modificar los riesgos, de manera de cumplir con los criterios de aceptación de riesgos de la organización.

10.5 Seguimiento y revisión

10.5.1 General

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 9.1.

El proceso de seguimiento de la organización (véase ISO/IEC 27001:2022, 9.1) debe abarcar todos los aspectos de los procesos de evaluación y tratamiento de riesgos con el fin de:

- a) garantizar que los tratamientos de riesgo sean eficaces, eficientes y económicos tanto en el diseño como en la operación;
- b) obtener información para mejorar futuras evaluaciones de riesgos;
- c) analizar y aprender lecciones de incidentes (incluidos cuasi accidentes), cambios, tendencias y éxitos y fracasos;
- d) detectar cambios en el contexto interno y externo, incluidos cambios en los criterios de riesgo y los propios riesgos, lo que puede requerir una revisión de los tratamientos y prioridades de los riesgos;
- e) identificar riesgos emergentes.

Los escenarios de riesgo retenidos, derivados de las actividades de gestión de riesgos, pueden transponerse a escenarios de seguimiento para garantizar un proceso de seguimiento eficaz. Para más detalles sobre los escenarios de seguimiento, consulte el apartado [A.2.7.](#) _____

10.5.2 Seguimiento y revisión de los factores que influyen en los riesgos

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 9.1.

Entrada: Toda la información de riesgo obtenida de las actividades de gestión de riesgos.

Acción: Los riesgos y sus factores (es decir, valor de los activos, consecuencias, amenazas, vulnerabilidades, probabilidad de ocurrencia) deben monitorearse y revisarse para identificar cualquier cambio en el contexto de la organización en una etapa temprana y para mantener una visión general del panorama completo de riesgos.

Desencadenante: Revisión de la política organizacional y cualquier detección de cambios en el entorno operativo o de amenazas actual.

Resultado: Alineación continua de la gestión de riesgos con los objetivos de negocio de la organización y con los criterios de aceptación de riesgos.

Guía de implementación:

La norma ISO/IEC 27001:2022, 9.1, exige que las organizaciones evalúen su desempeño en seguridad de la información (y la eficacia de su SGSI). De acuerdo con este requisito, las organizaciones deben utilizar sus planes de tratamiento de riesgos como base para sus evaluaciones de desempeño. Para ello, la organización debe definir primero una o más necesidades de información; por ejemplo, para describir lo que la alta dirección desea saber sobre la capacidad de la organización para defenderse de las amenazas. Utilizando esto como especificación de alto nivel, la organización debe determinar las mediciones que necesita realizar y cómo combinarlas para satisfacer la necesidad de información.

Los riesgos no son estáticos. Los escenarios de eventos, el valor de los activos, las amenazas, las vulnerabilidades, las probabilidades y las consecuencias pueden cambiar abruptamente sin previo aviso. Se debe realizar un monitoreo constante para detectar estos cambios. Esto puede respaldarse con servicios externos que proporcionen información sobre nuevas amenazas o vulnerabilidades. Las organizaciones deben garantizar el monitoreo continuo de factores relevantes, como:

- a) nuevas fuentes de riesgo, incluidas vulnerabilidades recientemente notificadas en TI;
- b) nuevos activos que hayan sido incluidos en el ámbito de gestión de riesgos;
- c) modificación necesaria de los valores de los activos (por ejemplo, debido a cambios en los requisitos comerciales);
- d) identificar vulnerabilidades para determinar quiénes quedan expuestos a amenazas nuevas o reemergentes;
- e) cambios en los patrones de uso de tecnologías existentes o nuevas que puedan abrir nuevas posibilidades o oportunidades de ataque;
- f) cambios en leyes y reglamentos;
- g) cambios en el apetito por el riesgo y en la percepción de lo que ahora es aceptable y lo que ya no lo es;
- h) incidentes de seguridad de la información, tanto dentro como fuera de la organización.

Nuevas fuentes de riesgo o cambios en la probabilidad o las consecuencias pueden aumentar los riesgos previamente evaluados. La revisión de los riesgos bajos y retenidos debe examinar cada riesgo por separado, así como todos los riesgos en su conjunto, para evaluar sus posibles consecuencias acumuladas. Si los riesgos ya no se clasifican en la categoría de riesgo bajo o aceptable, deben tratarse utilizando una o más de las opciones del [punto 8.2](#).

Los factores que afectan la probabilidad de ocurrencia de eventos y sus consecuencias pueden cambiar, al igual que los factores que afectan la idoneidad o el coste de las distintas opciones de tratamiento. Los cambios importantes que afecten a la organización deben justificar una revisión más específica. Las actividades de monitorización de riesgos deben repetirse periódicamente y las opciones seleccionadas para su tratamiento deben revisarse periódicamente.

ISO/IEC 27005:2022(E)

Nuevas amenazas, vulnerabilidades o cambios en la probabilidad o las consecuencias pueden incrementar los riesgos previamente evaluados como bajos. La revisión de los riesgos bajos y retenidos debe considerar cada riesgo por separado, así como todos los riesgos en su conjunto, para evaluar sus posibles consecuencias acumuladas. Si los riesgos no se clasifican como riesgos bajos o aceptables, deben tratarse utilizando una o más de las opciones contempladas en [la Cláusula 8](#).

Los factores que afectan la probabilidad de ocurrencia de amenazas y sus consecuencias pueden cambiar, al igual que los factores que afectan la idoneidad o el coste de las distintas opciones de tratamiento. Los cambios importantes que afecten a la organización deben justificar una revisión más específica. Las actividades de monitorización de riesgos deben repetirse periódicamente y las opciones seleccionadas para el tratamiento de riesgos deben revisarse periódicamente.

El resultado de las actividades de monitorización de riesgos puede servir de base para otras actividades de revisión de riesgos. La organización debe revisar todos los riesgos periódicamente y cuando se propongan o se produzcan cambios importantes, de acuerdo con la norma ISO/IEC 27001:2022, cláusula 8.

10.6 Revisión por la dirección

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 9.3.

Entrada: Resultados de las evaluaciones de riesgos de seguridad de la información, estado del plan de tratamiento de riesgos de seguridad de la información.

Acción: Se deben revisar los resultados de la evaluación de riesgos de seguridad de la información y el estado del plan de tratamiento de riesgos de seguridad de la información para confirmar que los riesgos residuales cumplen con los criterios de aceptación de riesgos y que el plan de tratamiento de riesgos aborda todos los riesgos relevantes y sus opciones de tratamiento de riesgos.

Desencadenante: Una parte del calendario programado de actividades de revisión.

Salida: Cambios en los criterios de aceptación de riesgos y en los criterios de ejecución de la información.
evaluaciones de riesgos de seguridad, plan de tratamiento de riesgos de seguridad de la información actualizado o SOA.

10.7 Acción correctiva

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 10.1.

Entrada: El plan de tratamiento del riesgo está resultando ineficaz, lo que significa que el riesgo residual permanecerá en niveles inaceptables una vez completado el plan de tratamiento.

Acción: Revisar el plan de tratamiento de riesgos e implementarlo para modificar el riesgo residual a un nivel aceptable.

Desencadenante: La decisión de revisar el plan de tratamiento de riesgos.

Resultado: Un plan de tratamiento de riesgos revisado y su implementación.

Guía de implementación: _____

Las no conformidades relacionadas con la eficacia del plan de tratamiento de riesgos pueden detectarse mediante una auditoría interna o externa, o mediante el seguimiento y los indicadores. El plan de tratamiento debe revisarse para reflejar:

- los resultados del proceso de tratamiento de riesgos de seguridad de la información;
- implementación progresiva del plan (por ejemplo, un control se implementa según lo especificado, según lo diseñado, según lo especificado) construido);
- dificultades identificadas en la implementación de controles (por ejemplo, problemas técnicos o financieros, inconsistencias con factores internos o externos como consideraciones de privacidad).

También hay casos en que, incluso si los riesgos residuales son aceptables una vez completado el plan de tratamiento, los usuarios rechazarán su uso o intentarán eludirlo porque estos controles no son aceptados por los usuarios en términos de facilidad de uso (por ejemplo, no son ergonómicos, demasiado complicados o demasiado largos).

La organización debe revisar la eficacia del plan de tratamiento revisado.

10.8 Mejora continua

NOTA Esta subcláusula se relaciona con ISO/IEC 27001:2022, 10.2

Entrada: Toda la información de riesgo obtenida de las actividades de gestión de riesgos.

Acción: El proceso de gestión de riesgos de seguridad de la información debe ser monitoreado, revisado y mejorado continuamente según sea necesario.

Desencadenante: La organización busca mejorar y madurar a partir de las lecciones aprendidas durante el proceso de gestión de riesgos de seguridad de la información.

Resultado: Relevancia continua del proceso de gestión de riesgos de seguridad de la información para los objetivos de negocio de la organización o actualización del proceso.

Guía de implementación: _____

El seguimiento y la revisión continuos de que el contexto, el resultado de la evaluación de riesgos y el tratamiento de los riesgos, así como los planes de gestión, sigan siendo pertinentes y apropiados a las circunstancias, son necesarios para garantizar que el proceso de gestión de riesgos de seguridad de la información sea correcto.

La organización debe garantizar que el proceso de gestión de riesgos de seguridad de la información y las actividades relacionadas sigan siendo adecuados en las circunstancias actuales y se cumplan. Cualquier mejora acordada en el proceso, o las acciones necesarias para mejorar el cumplimiento del mismo, deben notificarse a los responsables. Estos deben tener la garantía de que ningún riesgo o elemento de riesgo se pasa por alto o se subestima, y de que se toman las medidas y decisiones necesarias para proporcionar una comprensión realista de los riesgos y la capacidad de respuesta.

Es importante destacar que el proceso de gestión de cambios debe retroalimentación continua al proceso de gestión de riesgos con el fin de asegurar que las variaciones en los sistemas de información capaces de modificar los riesgos se tomen en cuenta oportunamente, modificando incluso las actividades de evaluación de riesgos para evaluarlos adecuadamente.

Además, la organización debe verificar periódicamente los criterios utilizados para medir el riesgo. Esta verificación debe garantizar que todos los elementos sigan siendo válidos y coherentes con los objetivos, estrategias y políticas del negocio, y que los cambios en el contexto empresarial se tengan debidamente en cuenta durante el proceso de gestión de riesgos de seguridad de la información. Esta actividad de supervisión y revisión debe abordar (entre otros):

- contexto jurídico y ambiental;
- contexto de competencia;
- enfoque de evaluación de riesgos;
- valor y categorías de los activos;
- criterios de consecuencia;
- criterios de verosimilitud;
- criterios de evaluación de riesgos;
- criterios de aceptación de riesgos;
- coste total de propiedad;
- recursos necesarios.

La organización debe garantizar que los recursos de evaluación y tratamiento de riesgos estén continuamente disponibles para revisar los riesgos, abordar amenazas o vulnerabilidades nuevas o modificadas y asesorar a la gerencia en consecuencia.

ISO/IEC 27005:2022(E)

El seguimiento de la gestión de riesgos puede dar lugar a modificaciones o ampliaciones del enfoque, la metodología o las herramientas utilizadas en función de:

- la madurez del riesgo de la organización;
- cambios identificados;
- iteración de la evaluación de riesgos;
- el objetivo del proceso de gestión de riesgos de seguridad de la información (por ejemplo, continuidad del negocio, resiliencia ante incidentes, cumplimiento);
- el objeto del proceso de gestión de riesgos de seguridad de la información (por ejemplo, organización, unidad de negocio, proceso de información, su implementación técnica, aplicación, conexión a Internet).

Los ciclos de gestión de riesgos relacionados con el alcance de la evaluación y el tratamiento de riesgos se presentan en [5.2](#).

Anexo A (informativo)

Ejemplos de técnicas de apoyo al proceso de evaluación de riesgos

A.1 Criterios de riesgo de seguridad de la información

A.1.1 Criterios relacionados con la evaluación de riesgos

A.1.1.1 Consideraciones generales sobre la evaluación de riesgos

En general, la incertidumbre personal predomina en la evaluación del riesgo de la información, y distintos analistas muestran distintas tendencias a la incertidumbre al interpretar los puntos de las escalas de probabilidad y consecuencia. Las escalas de referencia deben relacionar las categorías de consecuencia, probabilidad y riesgo con valores objetivos comunes, claramente especificados, posiblemente expresados en términos como la pérdida financiera en unidades monetarias y la frecuencia teórica de ocurrencia en un período finito, específicos del enfoque cuantitativo.

En particular, cuando se adopta el enfoque cualitativo, los analistas de riesgos deben recibir capacitación y práctica periódica frente a una escala de referencia de anclaje para mantener la calibración de su juicio.

A.1.1.2 Enfoque cualitativo

A.1.1.2.1 Escala de consecuencias

La [Tabla A.1](#) presenta un ejemplo de escala de consecuencias.

Tabla A.1 — Ejemplo de escala de consecuencias

Consecuencias	Descripción
5 – Catastrófico	Consecuencias sectoriales o regulatorias más allá de la organización Ecosistema(s) sectorial(es) sustancialmente impactado(s), con consecuencias que pueden ser duraderas. Y/o: dificultad, e incluso incapacidad, del Estado para garantizar una función reguladora o una de sus misiones de vital importancia. Y/o: consecuencias críticas sobre la seguridad de las personas y los bienes (crisis sanitaria, contaminación ambiental importante, destrucción de infraestructuras esenciales, etc.).
4 – Crítico	Consecuencias desastrosas para la organización Incapacidad de la organización para garantizar la totalidad o parte de su actividad, con posibles consecuencias graves para la seguridad de las personas y los bienes. Es muy probable que la organización no supere la situación (su supervivencia se ve amenazada), y los sectores de actividad o estatales en los que opera probablemente se verán ligeramente afectados, sin consecuencias duraderas.
3 – Serio	Consecuencias sustanciales para la organización Alta degradación del rendimiento de la actividad, con posibles consecuencias significativas para la seguridad de las personas y los bienes. La organización superará la situación con serias dificultades (operación en un modo altamente degradado), sin impacto sectorial ni estatal.
2 – Significativo	Consecuencias significativas pero limitadas para la organización Deterioro en el desempeño de la actividad sin consecuencias para la seguridad de las personas ni de los bienes. La organización superará la situación a pesar de algunas dificultades (operación en modo degradado).

ISO/IEC 27005:2022(E)

Tabla A.1 (continuación)

Consecuencias	Descripción
1 – Menor	Consecuencias insignificantes para la organización No habrá consecuencias para las operaciones ni el rendimiento de la actividad, ni para la seguridad de las personas y los bienes. La organización superará la situación sin demasiada dificultad (se agotarán los márgenes).

A.1.1.2.2 Escala de verosimilitud

Las Tablas A.2 y A.4 presentan ejemplos de formas alternativas de representar las escalas de verosimilitud. La verosimilitud puede expresarse en términos probabilísticos, como en la Tabla A.2, o en términos frecuentistas, como en la Tabla A.4. La representación probabilística indica la probabilidad promedio de que un evento de riesgo ocurra en un período específico, mientras que la representación frecuentista indica el número promedio de veces que se espera que ocurra dicho evento en un período específico. Dado que ambos enfoques simplemente expresan lo mismo desde dos perspectivas diferentes, se puede utilizar cualquiera de las dos representaciones, según la que la organización considere más conveniente para una categoría de riesgo determinada.

Sin embargo, si ambos enfoques se utilizan como alternativas dentro de la misma organización, es importante que cada rango nocionalmente equivalente en ambas escalas represente la misma probabilidad real. De lo contrario, los resultados de la evaluación dependen de la escala utilizada, en lugar de la probabilidad real de la fuente de riesgo evaluada. Si se utilizan ambos enfoques, el nivel probabilístico de cada rango nocional debe calcularse matemáticamente a partir del valor frecuentista del rango equivalente, o viceversa, según el enfoque utilizado para definir la escala principal.

Si se utiliza cualquiera de los dos enfoques por separado, no es necesario que los incrementos de la escala estén definidos con tanta precisión, ya que la priorización de las probabilidades puede lograrse independientemente de los valores absolutos utilizados. Si bien las Tablas A.2 y A.4 utilizan incrementos y rangos de probabilidad completamente diferentes, dependiendo del contexto de la organización y la categoría de riesgo que se evalúe, cualquiera de los dos puede ser igualmente eficaz para el análisis si se utilizan de forma exclusiva. Sin embargo, no serían utilizables de forma segura como alternativas en el mismo contexto, ya que los valores asignados a clasificaciones equivalentes no se correlacionan.

Las categorías y valores utilizados en las Tablas A.2 y A.4 son solo ejemplos. El valor más adecuado para cada nivel de probabilidad depende del perfil de riesgo y la tolerancia al riesgo de la organización.

Tabla A.2 — Ejemplo de escala de verosimilitud

Probabilidad	Descripción
5 – Casi seguro	La fuente de riesgo seguramente alcanzará su objetivo utilizando uno de los métodos de ataque considerados. La probabilidad del escenario de riesgo es muy alta.
4 – Muy probable	La fuente de riesgo probablemente alcanzará su objetivo utilizando uno de los métodos de ataque considerados. La probabilidad del escenario de riesgo es alta.
3 – Probable	La fuente de riesgo puede alcanzar su objetivo utilizando uno de los métodos de ataque considerados. La probabilidad del escenario de riesgo es significativa.
2 – Bastante improbable	La fuente de riesgo tiene relativamente pocas posibilidades de alcanzar su objetivo mediante el uso de uno de los métodos de ataque considerados. La probabilidad del escenario de riesgo es baja.
1 – Improbable	La fuente de riesgo tiene muy pocas posibilidades de alcanzar su objetivo utilizando uno de los métodos de ataque considerados. La probabilidad del escenario de riesgo es muy baja.

Se pueden añadir etiquetas verbales como "baja", "media" y "alta" a las clasificaciones al utilizar cualquiera de los dos enfoques para la evaluación de la probabilidad. Estas etiquetas pueden ser útiles al analizar los niveles de probabilidad con

Partes interesadas que no son especialistas en riesgos. Sin embargo, son subjetivas y, por lo tanto, inevitablemente ambiguas. Por consiguiente, no deben utilizarse como descriptores principales al realizar o informar evaluaciones.

A.1.1.2.3 Nivel de riesgo

La utilidad de las escalas cualitativas y la coherencia de las evaluaciones de riesgos que se derivan de ellas dependen enteramente de la coherencia con la que todas las partes interesadas interpretan las etiquetas de las categorías.

Los niveles de cualquier escala cualitativa deben ser inequívocos, sus incrementos deben estar claramente definidos, las descripciones cualitativas de cada nivel deben expresarse en un lenguaje objetivo y las categorías no deben superponerse entre sí.

Por consiguiente, al utilizar descriptores verbales de probabilidad, consecuencia o riesgo, estos deben referenciarse formalmente a escalas inequívocas basadas en puntos de referencia numéricos (como en [la Tabla A.4](#)) o racionales (como en [la Tabla A.2](#)). Todas las partes interesadas deben conocer las escalas de referencia para garantizar la coherencia en la interpretación de los datos y resultados de la evaluación cualitativa.

[En el cuadro A.3](#) se presenta un ejemplo de enfoque cualitativo.

Tabla A.3 — Ejemplo de enfoque cualitativo para los criterios de riesgo

Probabilidad	Consecuencia				
	Catastrófico	Crítico	Grave	Significativo	Leve
Casi seguro	Muy alto	Muy alto	Alto	Alto	Medio
Muy probable	Muy alto	Alto	Alto	Medio	Bajo
Probable	Alto	Alto	Medio	Bajo	Bajo
Bastante improbable	Mediano	Mediano	Bajo	Bajo	Muy bajo
Improbable	Bajo	Bajo	Bajo	Muy bajo	Muy bajo

El diseño de una matriz de riesgos cualitativa debe guiarse por los criterios de aceptación de riesgos de la organización (véanse [6.4.2](#) y [A.1.2](#)).

EJEMPLO Una organización a veces está más preocupada por las consecuencias extremas a pesar de que sea poco probable que ocurran, o está principalmente preocupada por eventos de alta frecuencia con consecuencias menores.

Al diseñar una matriz de riesgos, ya sea cualitativa o cuantitativa, el perfil de riesgo de una organización suele ser asimétrico. Los eventos triviales suelen ser los más frecuentes y la frecuencia esperada suele reducirse a medida que aumentan las consecuencias, lo que resulta en una probabilidad muy baja de consecuencias extremas. También es poco común que la exposición empresarial representada por un evento de alta probabilidad/baja consecuencia sea equivalente a la representada por un evento de baja probabilidad/alta consecuencia. Si bien una matriz de riesgos simétrica respecto a su diagonal de baja/baja a alta/alta puede parecer fácil de crear y aceptable a priori, es poco probable que represente con precisión el perfil de riesgo real de una organización y, por lo tanto, puede arrojar resultados inválidos. Para garantizar que una matriz de riesgos sea realista y cumpla con el requisito de mejora continua (véase ISO/IEC 27001:2022, 10.2), el razonamiento para asignar cada categoría a las escalas de probabilidad y consecuencia y a la matriz de riesgos, así como la concordancia de las categorías con el perfil de riesgo de la organización, debe documentarse al definir o modificar las escalas y la matriz. Como mínimo, las incertidumbres intrínsecas al uso de matrices de escala incremental deben describirse con las debidas precauciones para sus usuarios.

La utilidad de las escalas cualitativas y la coherencia de las evaluaciones de riesgos que se derivan de ellas dependen enteramente de la coherencia con la que todas las partes interesadas interpretan las etiquetas de las categorías.

Los niveles de cualquier escala cualitativa deben ser inequívocos, sus incrementos deben estar claramente definidos, las descripciones cualitativas de cada nivel deben expresarse en un lenguaje objetivo y las categorías no deben superponerse entre sí.

ISO/IEC 27005:2022(E)

A.1.1.3 Enfoque cuantitativo

A.1.1.3.1 Escalas finitas

El nivel de riesgo se puede calcular utilizando cualquier método y teniendo en cuenta cualquier factor relevante, pero normalmente se muestra multiplicando la probabilidad por la consecuencia.

La probabilidad representa la probabilidad o frecuencia de que un evento ocurra dentro de un período de tiempo determinado. Este período de tiempo suele ser anual (por año), pero puede ser tan grande (por ejemplo, por siglo) o tan pequeño (por ejemplo, por segundo) como lo desee la organización.

Las escalas de probabilidad deben definirse en términos prácticos que reflejen el contexto de la organización, de modo que faciliten la gestión del riesgo y sean fáciles de comprender para todas las partes interesadas. Esto implica, principalmente, establecer límites realistas para el rango de probabilidades representadas. Si los límites máximo y mínimo de la escala son demasiado distintos, cada categoría que la compone incluye un rango de probabilidades excesivamente amplio, lo que genera incertidumbre en la evaluación.

EJEMPLO 1 El punto de probabilidad finito más alto en la escala se puede definir de manera útil en términos del tiempo que normalmente le toma a la organización responder a los eventos, y el punto finito más bajo en términos de la duración de la planificación estratégica a largo plazo de la organización.

Las probabilidades por encima y por debajo de los límites definidos de la escala pueden expresarse útilmente como «mayor que el máximo de la escala» y «menor que el mínimo de la escala», lo que indica claramente que las probabilidades que exceden los límites de la escala definida son casos extremos que deben considerarse excepcionalmente (posiblemente utilizando criterios especiales de «fuera de límites»). Fuera de estos límites, la probabilidad específica es menos importante que el hecho de que sea una excepción en la dirección dada.

Generalmente es útil medir las consecuencias utilizando una cifra financiera, ya que esto permite la agregación para informar el riesgo.

EJEMPLO 2 Las escalas de consecuencias monetarias normalmente se basan en factores de 10 (100 a 1 000; 1 000 a 10 000, etc.).

Los anchos de las categorías de una escala de probabilidad deben seleccionarse con referencia a los de la escala de consecuencia elegida para evitar que un rango excesivo de riesgos caiga en cada categoría.

EJEMPLO 3 Si la probabilidad y la consecuencia están representadas por los índices de una escala exponencial (es decir, los logaritmos de los valores en la escala), estos deben sumarse.

El valor del riesgo se puede calcular entonces de la siguiente manera: antilogaritmo [logaritmo (valor de verosimilitud) + logaritmo (valor de consecuencia)].

Tabla A.4 — Ejemplo de escala de verosimilitud logarítmica

Frecuencia media aproximada	Expresión logarítmica	Valor de escala
Cada hora	(aproximadamente 105)	5
Cada 8 horas	(aproximadamente 104)	4
Dos veces por semana	(aproximadamente 103)	3
Una vez al mes	(aproximadamente 103)	2
Una vez al año	(101)	1
Una vez por década	(100)	0

EJEMPLO 4 En la [Tabla A.4](#), un ejemplo de evento de alta frecuencia es un ataque de contraseña asistido por computadora o un ataque de denegación de servicio distribuido de una botnet. De hecho, la frecuencia de los ataques puede ser mucho mayor.

EJEMPLO 5 En la [Tabla A.4](#), un ejemplo de evento de baja frecuencia son las erupciones volcánicas. Aunque se prevea que un evento solo ocurrirá una vez por siglo, eso no significa que no ocurrirá durante la vida útil de un SGSI.

[La Tabla A.5](#) muestra un ejemplo de una escala de consecuencias logarítmica. Uno de los objetivos de considerar la frecuencia es garantizar que las medidas de protección sean lo suficientemente robustas como para resistir secuencias de ataque de alta frecuencia, incluso cuando la probabilidad de que ocurran sea baja.

Tabla A.5 — Ejemplo de escala de consecuencias logarítmicas

Consecuencia (una pérdida de)	Expresión logarítmica	Valor de escala
£1 000 000	(106)	6
£100 000	(105)	5
£10 000	(104)	4
£1 000	(103)	3
£100	(102)	2
Menos de £100	(101)	1

Si tanto la escala de probabilidad como la de consecuencia utilizan una base logarítmica de 10 para asignar el nivel, los analistas de riesgos pueden terminar con demasiados riesgos en el mismo nivel de riesgo y no poder tomar una decisión adecuada de priorización o inversión en seguridad. En ese caso, puede ser útil reducir la base y aumentar el número de niveles considerados. Cabe señalar que si se eligen bases diferentes para la probabilidad y las consecuencias, no se puede aplicar una fórmula útil para sumar dos factores.

EJEMPLO 6: Si la probabilidad se duplica al pasar de un nivel al siguiente, mientras que la consecuencia es diez veces más costosa, la fórmula resultará en los riesgos a) y b), donde el riesgo b) tiene un nivel de consecuencia diez veces más costoso que el riesgo a), pero solo la mitad de la probabilidad de que el riesgo a) termine en el mismo nivel de riesgo. Esto es económicamente incorrecto.

[Las Tablas A.4 y A.5](#) enumeran rangos de probabilidad y consecuencia que cubren la mayoría de las eventualidades en organizaciones muy diversas. Es improbable que una sola organización se enfrente al rango de riesgo representado por la totalidad de estas escalas de ejemplo. El contexto de la organización y el alcance del SGSI deben utilizarse para definir límites superiores e inferiores realistas tanto para las probabilidades como para las consecuencias, teniendo en cuenta que cuantificar rangos de riesgo superiores a 1000 a 1 probablemente tenga un valor práctico limitado.

A.1.2 Criterios de aceptación de riesgos

Los criterios para la aceptación del riesgo pueden ser simplemente un valor por encima del cual los riesgos se consideran inaceptables.

por la [En la Tabla A.3](#), si se elige el valor medio, todos los riesgos con un valor muy bajo, bajo o medio serían considerados aceptables organización y todos los riesgos con un valor alto o muy alto serían considerados inaceptables.

Mediante una matriz de riesgos con código de colores que refleja las escalas de consecuencia y probabilidad, las organizaciones pueden presentar gráficamente la distribución del riesgo de una o varias evaluaciones de riesgo. Esta matriz también puede utilizarse para indicar la actitud de la organización ante los valores de riesgo e indicar si un riesgo debería aceptarse o tratarse normalmente.

EJEMPLO 2 Se puede aplicar una matriz de riesgo que utiliza tres colores, por ejemplo rojo, ámbar y verde, para representar tres grados de evaluación de riesgo, como se presenta en [la Tabla A.6](#).

Puede ser beneficioso elegir otros modelos utilizando colores para una matriz de riesgos.

EJEMPLO 3 Si se utiliza una matriz de riesgos para comparar los resultados de una evaluación de riesgos realizada originalmente con los resultados de una reevaluación de los mismos riesgos, la reducción del riesgo se puede presentar más fácilmente si se aplican más colores a los niveles de riesgo actuales.

También es posible añadir la determinación de qué nivel de gestión está autorizado a aceptar un riesgo con un cierto valor de riesgo para tal modelo.

[En la Tabla A.6](#) se presenta un ejemplo de escala de evaluación.

Tabla A.6 — Ejemplo de escala de evaluación combinada con matriz de riesgo de tres colores

Nivel de riesgo	Evaluación de riesgos	Descripción
Bajo (verde)	Aceptable tal como está	El riesgo puede aceptarse sin necesidad de realizar ninguna otra acción.
Moderado (ámbar)	Tolerable bajo control	Se debe realizar un seguimiento en materia de gestión de riesgos y establecer acciones en el marco de la mejora continua a medio y largo plazo.
Alto (rojo)	Inaceptable	Las medidas para reducir el riesgo deben tomarse a corto plazo. De lo contrario, se debe rechazar la actividad total o parcialmente .

A.2 Técnicas prácticas

A.2.1 Componentes de riesgo de seguridad de la información

Al identificar y evaluar los riesgos de seguridad de la información, se deben tener en cuenta los siguientes componentes:

- componentes relacionados con el pasado:
 - eventos e incidentes de seguridad (tanto dentro como fuera de la organización);
 - fuentes de riesgo;
 - vulnerabilidades explotadas;
 - consecuencias medidas;
- componentes relacionados con el futuro:
 - amenazas;
 - vulnerabilidades;
 - consecuencias;
 - escenarios de riesgo.

Las relaciones entre los componentes de riesgo de seguridad de la información se presentan en la [Figura A.1](#) y se analizan en [A.2.2](#) a [A.2.7](#).

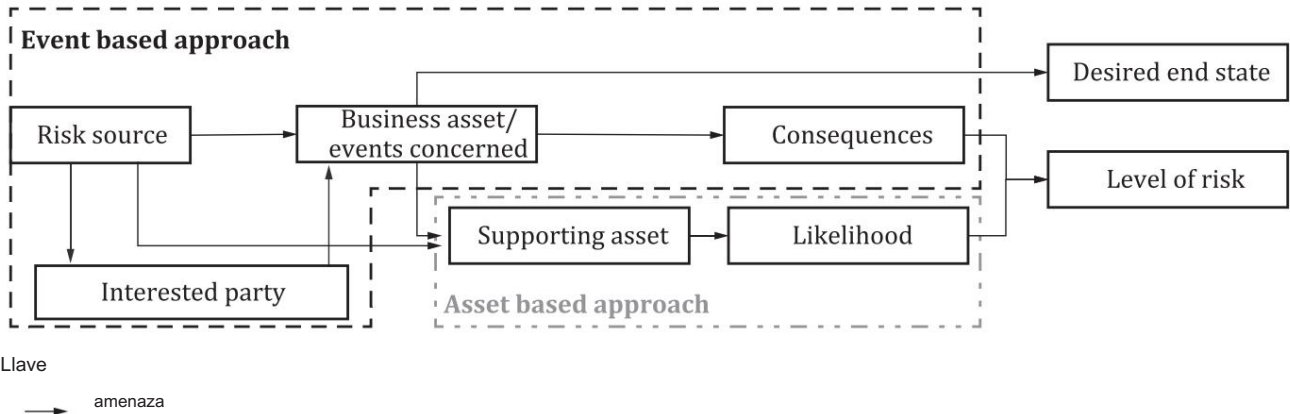


Figura A.1 — Componentes de la evaluación de riesgos de seguridad de la información

Los detalles sobre el “Estado final deseado” se pueden encontrar en [A.2.3](#) b).

A.2.2 Activos

Al aplicar el enfoque basado en activos a la identificación de riesgos, se deben identificar los activos.

En el proceso de evaluación de riesgos, dentro del desarrollo de escenarios de riesgo, la identificación de eventos, consecuencias, amenazas, vulnerabilidades, deben estar vinculadas a los activos.

En el proceso de tratamiento de riesgos, cada control es aplicable a un subconjunto de los activos.

Los activos se pueden dividir en dos categorías:

- activos primarios/comerciales: información o procesos de valor para una organización;
- activos de apoyo — componentes del sistema de información en los que se basan uno o varios activos comerciales se basan.

Los activos primarios/comerciales se utilizan a menudo en el enfoque basado en eventos (identificación de eventos y sus consecuencias sobre los activos comerciales).

Los activos de apoyo se utilizan a menudo en el enfoque basado en activos (identificación y análisis de vulnerabilidades y amenazas sobre estos activos) y en el proceso de tratamiento de riesgos (especificación de los activos a los que se debe aplicar cada control).

Los activos comerciales y de soporte están relacionados, por lo tanto, las fuentes de riesgo identificadas para los activos de soporte pueden afectar los activos comerciales.

Por esta razón, es importante identificar las relaciones entre los activos y comprender su valor para la organización. Una estimación errónea del valor de los activos puede llevar a una evaluación errónea de las consecuencias del riesgo, pero también puede afectar la comprensión de la probabilidad de las amenazas consideradas.

EJEMPLO 1 Un activo de soporte alberga un activo comercial (información en este caso).

Los datos están protegidos por controles internos y externos para evitar que una fuente de riesgo logre su objetivo relacionado con el activo empresarial aprovechando una vulnerabilidad en el activo de soporte. Al distinguir los diferentes tipos de activos, se deben documentar las dependencias entre ellos y evaluar la propagación del riesgo, de modo que se pueda documentar que el mismo riesgo no se evalúa dos veces: una cuando afecta al activo de soporte y otra cuando afecta a los activos principales. Los gráficos de dependencia de activos son herramientas útiles para representar dichas dependencias y garantizar que se hayan considerado todas.

EJEMPLO 2 El gráfico de [la Figura A.2 indica los](#) activos dependientes para el activo comercial “mostrar procesamiento de pedidos y facturas” y se puede leer de la siguiente manera:

- “Administrador” (tipo: recurso humano), quien, si no está capacitado adecuadamente, propaga un riesgo al activo.
- “Mantener TI” (tipo: servicio), que propaga el riesgo al activo.
- “Servidor” (tipo: hardware) o al activo “Red” (tipo: conectividad de red). El servidor, si se detiene el funcionamiento o la red mal configurada provocan el activo.
- “Portal web” (tipo: aplicación), dejar de ejecutarse o no estar disponible.

Sin un “portal web”, el proceso comercial “que muestra el procesamiento de pedidos y facturas” no ofrece el proceso previsto a los clientes.

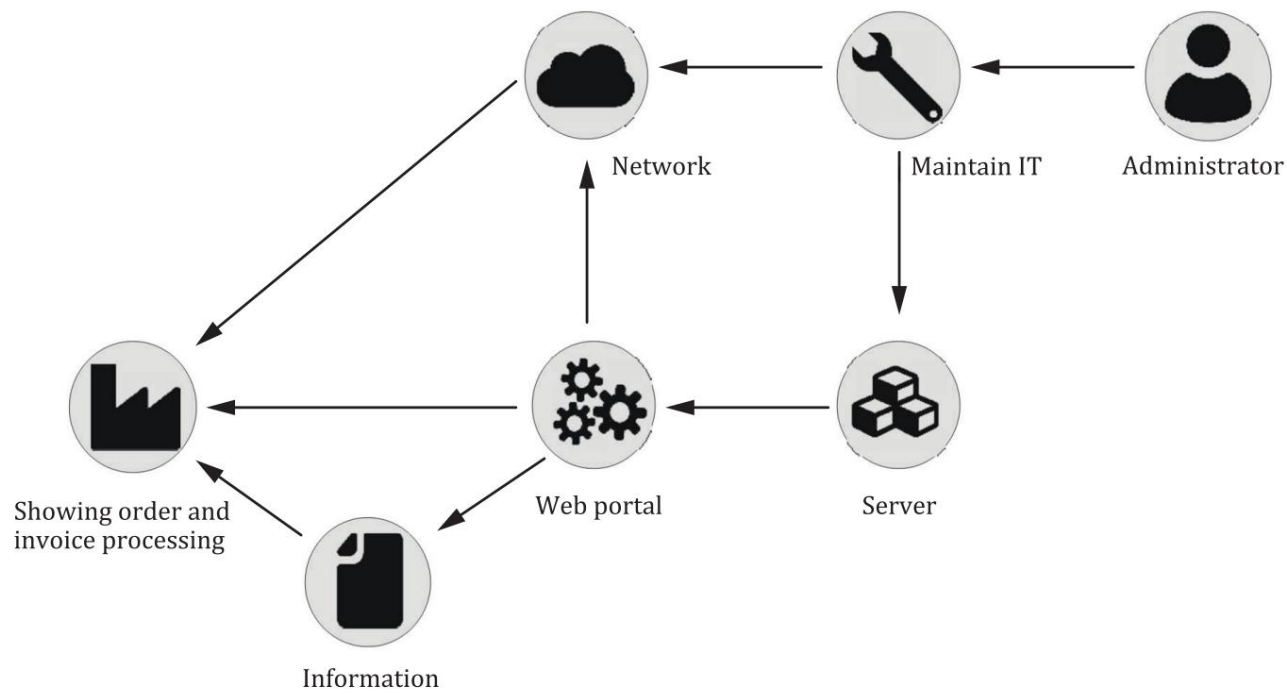


Figura A.2 — Ejemplo de un gráfico de dependencia de activos

A.2.3 Fuentes de riesgo y estado final deseado

Este párrafo propone caracterizar este tipo de fuentes de riesgo. Dos criterios principales estructuran este enfoque descriptivo:

- la motivación;
- la capacidad de actuar.

a) Identificación de la fuente de riesgo

En la Tabla A.7 se presentan ejemplos y métodos habituales de ataque.

Tabla A.7 — Ejemplos y métodos habituales de ataque

Fuente de riesgo	Ejemplos y métodos habituales de ataque
Relacionado con el Estado	Estados, agencias de inteligencia Método: Ataques generalmente realizados por profesionales que trabajan con un calendario y un método de ataque predefinidos. Este perfil de atacante se caracteriza por su capacidad para llevar a cabo una operación ofensiva durante un largo periodo de tiempo (recursos y procedimientos estables) y para adaptar sus herramientas y métodos a la topología del objetivo. Por extensión, estos actores tienen los medios para comprar o descubrir vulnerabilidades de día cero y algunos son capaces de infiltrarse en redes aisladas y realizar ataques sucesivos para alcanzar uno o varios objetivos (por ejemplo, mediante un ataque dirigido a la cadena de suministro).
Crimen organizado Organizaciones cibercriminales (mafias, bandas, grupos criminales)	Método: Estafas en línea o en persona, solicitud de rescate o ataque mediante ransomware, uso de botnets , etc. Debido, en particular, a la proliferación de kits de ataque fácilmente disponibles en línea, los cibercriminales realizan operaciones cada vez más sofisticadas y organizadas con fines lucrativos o fraudulentos. Algunos tienen los medios para comprar o descubrir vulnerabilidades de día cero.

Tabla A.7 (continuación)

Fuente de riesgo	Ejemplos y métodos habituales de ataque
Terrorista	Ciberterroristas, cibermilicias Método: Ataques normalmente poco sofisticados pero que se llevan a cabo con determinación y con fines de desestabilización y destrucción: denegación de servicio (por ejemplo, para indisponer los servicios de urgencia de un centro hospitalario, paradas intempestivas de un sistema industrial de producción de energía), explotación de vulnerabilidades de sitios de Internet y desfiguración.
Activistas ideológicos Ciberhacktivistas, grupos de interés, sectas	Método: Los métodos de ataque y la sofisticación de los ataques son relativamente similares a los de los ciberterroristas, pero están motivados por intenciones menos destructivas. Algunos actores llevan a cabo estos ataques para transmitir una ideología, un mensaje (por ejemplo, el uso masivo de las redes sociales como plataforma de difusión).
Equipos especializados con perfil de "cibermercenario" y capacidades informáticas generalmente altas desde el punto de vista técnico. Por ello, debe distinguirse de los script-kiddies, con quienes comparte el espíritu de desafío y la búsqueda de reconocimiento, pero con un objetivo lucrativo.	Estos grupos pueden organizarse como equipos especializados que ofrecen auténticos servicios de piratería informática. Método: Este tipo de hacker experimentado suele estar detrás del diseño y la creación de kits y herramientas de ataque disponibles en línea (posiblemente de pago), que luego pueden ser utilizados directamente por otros grupos de atacantes. No hay motivaciones particulares aparte del lucro.
Aficionado	Perfil del hacker script-kiddies o con buenos conocimientos informáticos; motivado por la búsqueda de reconocimiento social, diversión, desafío. Método: Ataques básicos pero con capacidad de utilizar los kits de ataque que están disponibles en línea.
Vengador	Las motivaciones de este perfil de atacante están guiadas por un espíritu de venganza agudo o un sentimiento de injusticia (por ejemplo, empleado despedido por falta grave, proveedor de servicios descontento tras un contrato no renovado, etc.). Método: Este perfil de atacante se caracteriza por su determinación y su conocimiento interno de los sistemas y procesos organizacionales. Esto puede hacerlo formidable y otorgarle un poder considerable para causar daño.
Atacante patológico	Las motivaciones de este perfil de atacante son de naturaleza patológica u oportunista y en ocasiones están guiadas por el motivo de lucro (por ejemplo, competidor desleal, cliente deshonesto, estafador y defraudador). Método: En este caso, los atacantes cuentan con conocimientos informáticos que les permiten intentar comprometer el sistema de información de su objetivo, utilizan los kits de ataque disponibles en línea o deciden subcontratar el ataque informático recurriendo a una organización especializada. En ciertos casos, los atacantes pueden dirigir su atención a una fuente interna (un empleado descontento, un proveedor de servicios sin escrúpulos) e intentar corromperla.

b) Modelar la motivación de una fuente de riesgo: estado final deseado

Las motivaciones son muy variadas: pueden ser políticas, financieras, ideológicas, pero también sociales o incluso representar un estado psicológico puntual o patológico.

Si bien no es posible expresar directamente una motivación, esta puede ilustrarse mediante la intención de la fuente de riesgo y expresarse en forma de un estado final deseado (EDD): la situación general que la fuente de riesgo desea alcanzar tras la confrontación. Una clasificación sistemática de situaciones, asociada a categorías generales de acción, puede guiar el análisis contextualizado.

En la [Tabla A.8](#) se presenta un ejemplo de clasificación de las motivaciones para expresar la DES.

Tabla A.8 — Ejemplo de clasificación de las motivaciones para expresar el DES

Conquistar	Captura a largo plazo de recursos o mercados económicos, ganando poder político o imponiendo valores.
Adquirir	Enfoque depredador, decididamente ofensivo, impulsado por la captura de recursos o beneficios.
Prevenir	Enfoque ofensivo para limitar las acciones de un tercero
Mantener	Esfuerzos para mantener una situación ideológica, política, económica o social.
Defender	Adoptar una postura de repliegue estrictamente defensiva o una actitud explícitamente amenazante (por ejemplo, intimidación) para evitar el comportamiento agresivo de un oponente claramente designado o evitar su acción ralentizándolo, etc.
Sobrevivir	Proteger una entidad a toda costa, lo que puede llevar a acciones extremadamente agresivas.

c) Objetivos meta

Para alcanzar el DES, la fuente de riesgo se centra en uno o varios objetivos que impactan los activos de negocio del sistema objetivo. Estos son los objetivos objetivo de la fuente de riesgo.

[El cuadro A.9](#) presenta ejemplos de objetivos meta.

Tabla A.9 — Ejemplos de objetivos meta

Objetivo	Objetivo Descripción
Espionaje	Operación de inteligencia (estatal, económica). En muchos casos, el atacante busca una instalación a largo plazo en el sistema de información con total discreción. El armamento, el espacio, la aeronáutica, el sector farmacéutico, la energía y ciertas actividades del Estado (economía, finanzas y política exterior) son objetivos privilegiados.
Preposicionamiento estratégico	El preposicionamiento generalmente tiene como objetivo un ataque a largo plazo, sin que el propósito final esté claramente establecido (por ejemplo, comprometer las redes de operadores de telecomunicaciones, infiltrarse en sitios web de información masiva para lanzar una operación de influencia política o económica con gran repercusión). La vulneración repentina y masiva de ordenadores para formar una botnet puede clasificarse en esta categoría.
Influencia	Operación destinada a difundir información falsa o alterarla, movilizar a líderes de opinión en las redes sociales, destruir reputaciones, divulgar información confidencial y degradar la imagen de una organización o de un Estado. El objetivo final suele ser desestabilizar o modificar la percepción.
Obstáculo para el funcionamiento	Operación de sabotaje cuyo objetivo es, por ejemplo, indisponibilidad de un sitio Internet, saturación de información, impedir el uso de un recurso digital o indisponibilidad de una instalación física. Los sistemas industriales pueden estar especialmente expuestos y vulnerables a través de las redes informáticas con las que están interconectados (por ejemplo, enviando comandos para provocar daños en el hardware o una avería que requiera un mantenimiento exhaustivo). Los ataques de denegación de servicio distribuido (DDoS) son técnicas comunes para neutralizar los recursos digitales.
Lucrativo	Operación con fines lucrativos, ya sea directa o indirectamente. Generalmente vinculada al crimen organizado, se pueden mencionar: fraude en internet, blanqueo de capitales, extorsión o malversación de fondos, manipulación del mercado financiero, falsificación de documentos administrativos, suplantación de identidad, etc. Ciertas operaciones con fines de lucro pueden utilizar un método de ataque que forma parte de las categorías anteriores (por ejemplo, espionaje y robo de datos, ransomware para neutralizar una actividad), pero el objetivo final sigue siendo financiero.
Desafío, diversión	Operación encaminada a cumplir una hazaña con fines de reconocimiento social, desafío o simplemente por diversión. Aunque el objetivo es principalmente la diversión y sin ningún deseo particular de hacer daño, este tipo de operaciones puede tener graves consecuencias para la víctima.

La diferencia entre un DES y un objetivo objetivo puede ilustrarse con el ejemplo de una fuente de riesgo cuyo objetivo es ganar un trato (DES) y que busca robar información confidencial sobre las negociaciones a su competidor (objetivo estratégico). En ocasiones, el objetivo en cuestión (la información deseada) no se traduce finalmente en el DES.

Se puede considerar que el valor del objetivo desde el punto de vista de la fuente de riesgo se basa en su contribución al DES.

En términos muy generales, los objetivos de la fuente de riesgo se dividen en dos grandes clases:

- explotar recursos objetivo para su propio beneficio, por ejemplo, espionaje, robo, estafa, fraude, tráfico;
- impedir que el objetivo utilice sus recursos (la confrontación siempre es relativa), por ejemplo, la guerra, el terrorismo, sabotaje, subversión, desestabilización.

A.2.4 Enfoque basado en eventos

A.2.4.1 Ecosistema

En un enfoque basado en eventos, los escenarios deben construirse analizando los diferentes caminos, relevantes para las interacciones entre la organización y las partes interesadas, que forman un ecosistema que las fuentes de riesgo pueden utilizar para llegar a los activos del negocio y su DES.

Un número cada vez mayor de métodos de ataque utilizan los enlaces más vulnerables de dicho ecosistema para alcanzar sus objetivos.

Las partes interesadas en el ámbito del SGSI que deben tenerse en cuenta al analizar los escenarios de riesgo pueden ser de dos tipos:

— partes externas, incluidas:

- clientes;
- socios, co-contratistas;
- proveedores de servicios (subcontratistas, proveedores).

— partes internas, incluidas:

- proveedores de servicios técnicos relacionados (por ejemplo, servicios de soporte propuestos por la gestión de TI);
- proveedores de servicios relacionados con la empresa (por ejemplo, entidad comercial que utiliza datos comerciales);
- filiales (en particular, situadas en otros países).

El objetivo de la identificación de las partes interesadas es obtener una visión clara del ecosistema para identificar a las más vulnerables. El conocimiento del ecosistema debe abordarse como un estudio preliminar de riesgos. [La Figura A.3 muestra la identificación de las partes interesadas del ecosistema.](#)

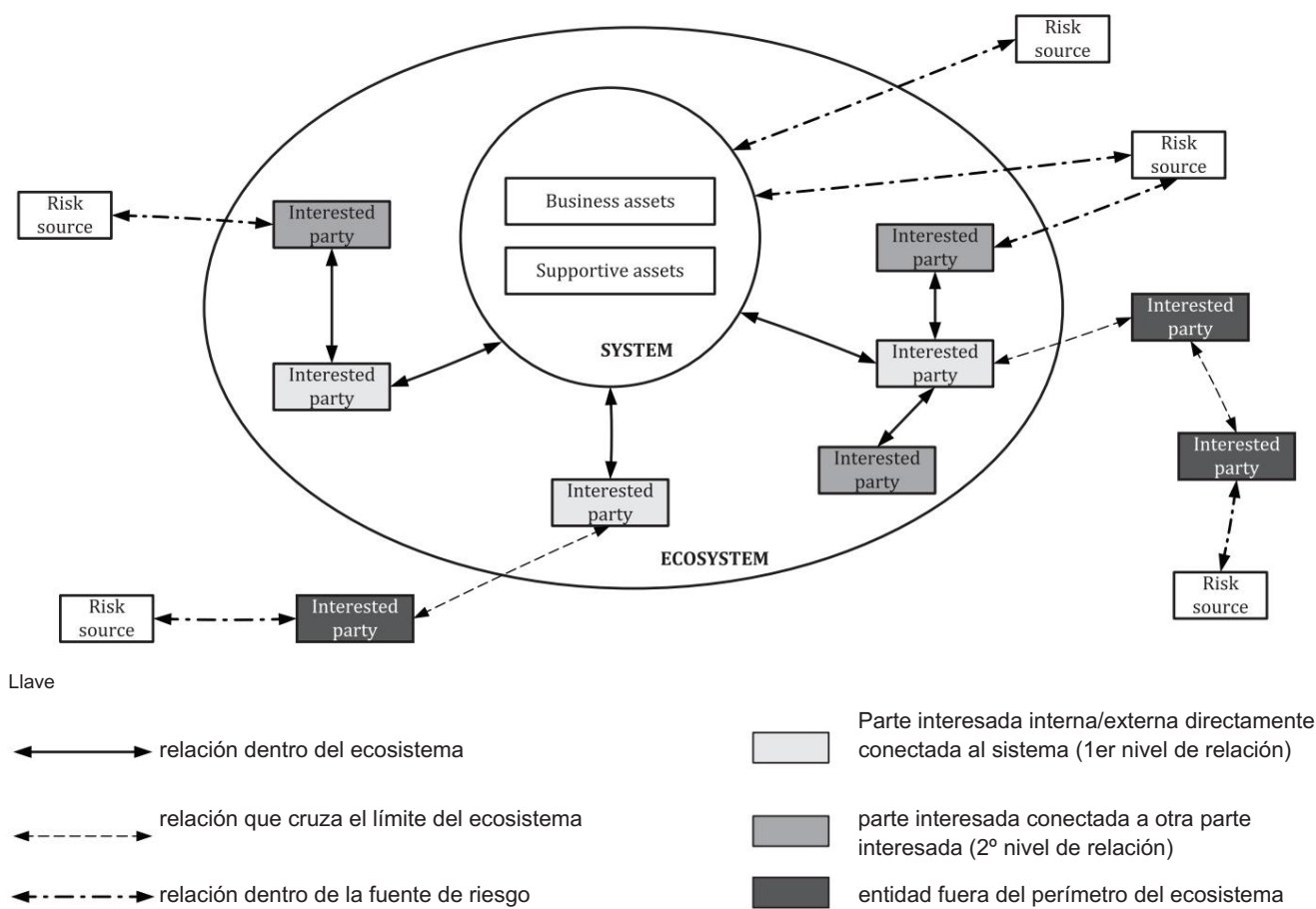


Figura A.3 — Identificación de las partes interesadas del ecosistema

A.2.4.2 Escenarios estratégicos

Con base en la información sobre las fuentes de riesgo y los eventos involucrados, se pueden imaginar escenarios realistas de alto nivel (escenarios estratégicos) que indican cómo una fuente de riesgo puede proceder para alcanzar su DES. Puede, por ejemplo, atravesar el ecosistema o desviar algunos procesos de negocio. Estos escenarios se identifican por deducción, a partir de las fuentes de riesgo y su DES: para cada uno de ellos, se pueden plantear las siguientes preguntas, desde la perspectiva de la fuente de riesgo:

- ¿Cuáles son los activos comerciales de la organización a los que las fuentes de riesgo deben apuntar para alcanzar sus objetivos? ¿su DES?
- Para posibilitar o facilitar su ataque, ¿es probable que ataquen a las partes interesadas críticas del ecosistema que tienen acceso privilegiado a los activos del negocio?

Una vez identificados los elementos más expuestos, se puede trazar el escenario estratégico, describiendo la secuencia de eventos generados por la fuente de riesgo para alcanzar su DES. La vulneración de los activos del negocio corresponde a eventos finales, mientras que los eventos relacionados con el ecosistema son intermedios. El escenario estratégico refleja una evaluación de consecuencias derivada directamente de los eventos en cuestión.

Estos escenarios se pueden representar en forma de gráficos de ataque o directamente en la vista del ecosistema del mapeo del sistema de información superponiendo las rutas de ataque.

Los escenarios estratégicos requieren una consideración adicional de la probabilidad de los eventos. El enfoque basado en activos y los escenarios operativos asociados pueden utilizarse para definir la probabilidad de los eventos. Los ejemplos de amenazas presentados en [A.2.5.1](#) pueden utilizarse para obtener las evaluaciones necesarias.

A.2.5 Enfoque basado en activos

A.2.5.1 Ejemplos de amenazas

La [Tabla A.10](#) presenta ejemplos de amenazas típicas. Esta lista puede utilizarse durante el proceso de evaluación de amenazas. Las amenazas consideradas fuentes de riesgo pueden ser deliberadas, accidentales o ambientales (naturales) y pueden provocar, por ejemplo, daños o la pérdida de servicios esenciales. La lista indica, para cada tipo de amenaza, dónde D (deliberada), A (accidental) y E (ambiental) son relevantes. D se utiliza para todas las acciones deliberadas dirigidas a la información y los activos relacionados con ella; A se utiliza para todas las acciones humanas que pueden dañar accidentalmente la información y los activos relacionados con ella; y E se utiliza para todos los incidentes no relacionados con acciones humanas. Los grupos de amenazas no están ordenados por prioridad.

Los controles pueden mitigar las amenazas disuadiéndolas o impidiéndoles que actúen o ocurran.

La selección de controles para reducir el riesgo también requiere considerar controles de detección y respuesta que identifiquen, respondan, contengan y se recuperen de los eventos. Estos controles se asocian con consecuencias más que con amenazas.

EJEMPLO El registro y la supervisión permiten la identificación y respuesta ante eventos de seguridad.

Tabla A.10 — Ejemplos de amenazas típicas

Categoría	No.	Descripción de la amenaza	Tipo de riesgo fuente ^a
Amenazas físicas	TP01	Fuego	A, D, E
	TP02	Agua	A, D, E
	TP03	Contaminación, radiaciones nocivas	A, D, E
	TP04	Accidente grave	A, D, E
	TP05	Explosión	A, D, E
	TP06	Polvo, corrosión, congelación	A, D, E
Amenazas naturales	TN01	Fenómeno climático	mi
	TN02	Fenómeno sísmico	mi
	TN03	Fenómeno volcánico	mi
	TN04	Fenómeno meteorológico	mi
	TN05	Inundación	mi
	TN06	Fenómeno pandémico/epidémico	mi
Fallas de infraestructura	TI01	Fallo de un sistema de suministro	A, D
	TI02	Falla del sistema de refrigeración o ventilación	A, D
	TI03	Pérdida de suministro de energía	A, D, E
	TI04	Fallo de una red de telecomunicaciones	A, D, E
	TI05	Fallo de equipos de telecomunicaciones	A, D
	TI06	Radiación electromagnética	A, D, E
	TI07	Radiación térmica	A, D, E
	TI08	Pulsos electromagnéticos	A, D, E
Fallos técnicos	TT01	Fallo de dispositivo o sistema	A
	TT02	Saturación del sistema de información	A, D
	TT03	Violación de la mantenibilidad del sistema de información	A, D
	TH01	Terrorismo, ataque, sabotaje	A, D
	TH02		
	TH03	Ingeniería social	D
		Interceptación de la radiación de un dispositivo	D
			D

^a D = deliberado; A = accidental; E = ambiental.

Tabla A.10 (continuación)

Categoría	No.	Descripción de la amenaza	Tipo de riesgo fuente ^a
Acciones humanas TH	TH04	Espionaje remoto	D
	TH05	Escuchas clandestinas	D
	TH06	Robo de medios o documentos	D
	TH07	Robo de equipo	D
	TH08	Robo de identidad o credenciales digitales	D
	TH09	Recuperación de medios reciclados o desechados	D
	TH10	Divulgación de información	A, D
	TH11	Entrada de datos de fuentes no confiables	A, D
	TH12	Manipulación del hardware	D
	TH13	Manipulación del software	A, D
	TH14	Exploits drive-by mediante comunicación basada en web	D
	TH15	Ataque de repetición, ataque de intermediario	D
	TH16	Tratamiento no autorizado de datos personales	A, D
	TH17	Entrada no autorizada a las instalaciones	D
	TH18	Uso no autorizado de dispositivos	D
	TH19	Uso incorrecto de dispositivos	A, D
	TH20	Dispositivos o medios dañinos	A, D
	TH21	Copia fraudulenta de software	D
	TH22	Uso de software falsificado o copiado	A, D
	TH23	Corrupción de datos	D
	TH24	Tratamiento ilícito de datos	D
	TH25	Envío o distribución de malware	A, D, R
	TH26	Detección de posición	D
Compromiso de funciones o servicios	TC01	Error en el uso	A
	TC02	Abuso de derechos o permisos	A, D
	TC03	Falsificación de derechos o permisos	D
	TC04	Denegación de acciones	D
Amenazas organizacionales	TO01	Falta de personal	A, E
	TO02	Falta de recursos	A, E
	TO03	Falta de los proveedores de servicios	A, E
	TO04	Violación de leyes o reglamentos	A, D

^a D = deliberado; A = accidental; E = ambiental.

A.2.5.2 Ejemplos de vulnerabilidades

La Tabla A.11 presenta ejemplos de vulnerabilidades en diversas áreas de seguridad, incluyendo ejemplos de amenazas que pueden explotarlas. Las listas pueden ser útiles durante la evaluación de amenazas y vulnerabilidades para determinar escenarios de riesgo relevantes. En algunos casos, otras amenazas también pueden explotar estas vulnerabilidades.

Tabla A.11 — Ejemplos de vulnerabilidades típicas

Categoría	No.	Ejemplos de vulnerabilidades
Hardware	VH01	Mantenimiento insuficiente/instalación defectuosa de los medios de almacenamiento
	VH02	Esquemas insuficientes de reemplazo periódico de equipos
	VH03	Susceptibilidad a la humedad, polvo y suciedad.
	VH04	Sensibilidad a la radiación electromagnética
	VH05	Control de cambio de configuración insuficiente
	VH06	Susceptibilidad a variaciones de tensión
	VH07	Susceptibilidad a las variaciones de temperatura
	VH08	Almacenamiento sin protección
	VH09	Falta de cuidado en la disposición
	VH10	Copia sin control
Software	VS01	Pruebas de software nulas o insuficientes
	VS02	Fallas conocidas en el software
	VS03	No se puede cerrar sesión al salir de la estación de trabajo
	VS04	Eliminación o reutilización de medios de almacenamiento sin borrado adecuado
	VS05	Configuración insuficiente de registros para fines de registro de auditoría
	VS06	Asignación incorrecta de derechos de acceso
	VS07	Software de amplia distribución
	VS08	Aplicar programas de aplicación a datos erróneos en términos de tiempo
	VS09	Interfaz de usuario complicada
	VS10	Documentación insuficiente o falta de documentación
	VS11	Configuración de parámetros incorrecta
	VS12	Fechas incorrectas
	VS13	Mecanismos de identificación y autenticación insuficientes (por ejemplo, para la autenticación de usuarios)
	VS14	Tablas de contraseñas desprotegidas
	VS15	Gestión deficiente de contraseñas
	VS16	Servicios innecesarios habilitados
	VS17	Software inmaduro o nuevo
	VS18	Especificaciones poco claras o incompletas para desarrolladores
	VS19	Control de cambios ineficaz
	VS20	Descarga y uso incontrolado de software
	VS21	Falta de copias de seguridad o copias de seguridad incompletas
	VS22	No presentación de informes de gestión
Red	VN01	Mecanismos insuficientes para la prueba de envío o recepción de un mensaje
	VN02	Líneas de comunicación sin protección
	VN03	Tráfico sensible sin protección
	VN04	Cableado conjunto deficiente
	VN05	Punto único de falla
	VN06	Ineficacia o ausencia de mecanismos de identificación y autenticación del remitente y receptor
	VN07	Arquitectura de red insegura
	VN08	Transferencia de contraseñas en claro
	VN09	Gestión inadecuada de la red (resiliencia del enrutamiento)
	VN10	Conexiones de red pública sin protección

Tabla A.11 (continuación)

Categoría	No.	Ejemplos de vulnerabilidades
Personal	VP01	Ausencia de personal
	VP02	Procedimientos de reclutamiento inadecuados
	VP03	Capacitación en seguridad insuficiente
	VP04	Uso incorrecto de software y hardware
	VP05	Poca conciencia de seguridad
	VP06	Insuficiencia o ausencia de mecanismos de seguimiento
	VP07	Trabajo no supervisado por personal externo o de limpieza
	VP08	Políticas ineficaces o inexistentes para el uso correcto de los medios de telecomunicaciones y mensajería
Sitio	VS01	Uso inadecuado o descuidado del control de acceso físico a edificios y salas
	VS02	Ubicación en zona susceptible a inundaciones
	VS03	Red eléctrica inestable
	VS04	Protección física insuficiente del edificio, puertas y ventanas
Organización	VO01	No se ha desarrollado un procedimiento formal para el registro y baja de usuarios, o su implementación es ineficaz
	VO02	No se ha desarrollado un proceso formal para la revisión (supervisión) del derecho de acceso o su implementación es ineficaz
	VO03	Disposiciones insuficientes (en materia de seguridad) en los contratos con clientes y/o terceros
	VO04	Procedimiento de seguimiento de las instalaciones de procesamiento de información no desarrollado, o su implementación es ineficaz
	VO05	Auditorías (supervisión) no realizadas de forma regular
	VO06	Procedimientos de identificación y evaluación de riesgos no desarrollados, o su implementación es ineficaz
	VO07	Insuficientes o nulos informes de fallas registrados en los registros del administrador y del operador
	VO08	Respuesta inadecuada al mantenimiento del servicio
	VO09	Acuerdo de Nivel de Servicio insuficiente o nulo
	VO10	Procedimiento de control de cambios no desarrollado o su implementación es ineficaz
	VO11	No se ha desarrollado un procedimiento formal para el control de la documentación del SGSI o su implementación es ineficaz
	VO12	No se ha desarrollado un procedimiento formal para la supervisión de registros del SGSI o su implementación es ineficaz
	VO13	No se ha desarrollado el proceso formal para la autorización de información públicamente disponible, o su implementación es ineficaz
	VO14	Asignación inadecuada de responsabilidades de seguridad de la información
	VO15	Los planes de continuidad no existen, están incompletos o están desactualizados
	VO16	No se ha desarrollado una política de uso del correo electrónico o su implementación es ineficaz
	VO17	Los procedimientos para introducir software en sistemas operativos no están desarrollados o su implementación es ineficaz
	VO18	No se han desarrollado procedimientos para el manejo de información clasificada o su implementación es ineficaz
	VO19	Las responsabilidades de seguridad de la información no están presentes en las descripciones de puestos
	VO20	Insuficiencia o ausencia de disposiciones (relativas a la seguridad de la información) en los contratos con empleados
	VO21	Proceso disciplinario en caso de incidente de seguridad de la información no definido, o no funcionando correctamente
	VO22	No se ha desarrollado una política formal sobre el uso de computadoras móviles, o su implementación es insuficiente. ineficaz

Tabla A.11 (continuación)

Categoría	No.	Ejemplos de vulnerabilidades
	VO23	Control insuficiente de los activos fuera de las instalaciones
	VO34	Insuficiencia o falta de una política de "escritorio y pantalla limpios"
	Autorización de instalaciones de procesamiento de información VO25	no implementada o no funcionando adecuadamente
	VO26	Mecanismos de monitoreo de brechas de seguridad no implementados adecuadamente
	VO27	Procedimientos para reportar debilidades de seguridad no desarrollados, o su implementación es ineficaz
	VO28	No se han desarrollado procedimientos de cumplimiento de disposiciones sobre derechos intelectuales, o su implementación es ineficaz

A.2.5.3 Métodos para la evaluación de vulnerabilidades técnicas

Se pueden utilizar métodos proactivos como las pruebas de sistemas de información para identificar vulnerabilidades dependiendo de la criticidad del sistema de tecnología de la información y las comunicaciones (TIC) y de los recursos disponibles (por ejemplo, fondos asignados, tecnología disponible, personas con la experiencia para realizar la prueba).

Los métodos de prueba incluyen:

- herramienta automatizada de escaneo de vulnerabilidades;
- pruebas y evaluación de seguridad;
- pruebas de penetración;
- revisión de código.

Se utiliza una herramienta automatizada de escaneo de vulnerabilidades para escanear un grupo de hosts o una red en busca de servicios vulnerables conocidos [por ejemplo, el sistema permite el Protocolo de Transferencia de Archivos (FTP) anónimo, retransmisión de Sendmail]. Sin embargo, algunas de las vulnerabilidades potenciales identificadas por la herramienta de análisis automatizado no necesariamente representan vulnerabilidades reales en el contexto del entorno del sistema (por ejemplo, algunas de estas herramientas de análisis evalúan las vulnerabilidades potenciales sin considerar el entorno ni los requisitos del sitio). Es posible que algunas de las vulnerabilidades señaladas por el software de análisis automatizado no sean vulnerables a un sitio específico, pero pueden configurarse como tal porque su entorno lo requiere. Por lo tanto, este método de prueba puede generar falsos positivos.

Las pruebas y evaluaciones de seguridad (STE) son otra técnica que permite identificar vulnerabilidades en sistemas TIC durante el proceso de evaluación de riesgos. Incluyen el desarrollo y la ejecución de un plan de pruebas (p. ej., script de prueba, procedimientos de prueba y resultados esperados). El propósito de las pruebas de seguridad del sistema es evaluar la eficacia de los controles de seguridad de un sistema TIC tal como se han aplicado en un entorno operativo. El objetivo es garantizar que los controles aplicados cumplan con las especificaciones de seguridad aprobadas para el software y el hardware, e implementen la política de seguridad de la organización o cumplan con los estándares del sector.

Las pruebas de penetración pueden utilizarse para complementar la revisión de los controles de seguridad y garantizar la seguridad de los diferentes aspectos del sistema TIC. Al emplearse en el proceso de evaluación de riesgos, permiten evaluar la capacidad de un sistema TIC para resistir intentos intencionales de evadir la seguridad. Su objetivo es evaluar el sistema TIC desde la perspectiva de una fuente de amenaza e identificar posibles fallos en sus esquemas de protección.

La revisión de código es la forma más exhaustiva (pero también la más costosa) de evaluar la vulnerabilidad.

Los resultados de este tipo de pruebas de seguridad ayudan a identificar las vulnerabilidades de un sistema.

Las herramientas y técnicas de penetración pueden dar resultados falsos a menos que se explote con éxito la vulnerabilidad. Para explotar vulnerabilidades específicas, es necesario conocer la configuración exacta del sistema, la aplicación y los parches en el sistema probado. Si no se conocen estos datos al momento de la prueba, no es necesariamente posible explotar una vulnerabilidad específica con éxito (por ejemplo, obtener acceso remoto a la shell inversa). Sin embargo,

ISO/IEC 27005:2022(E)

Aún es posible bloquear o reiniciar un proceso o sistema probado. En tal caso, el objeto probado debe ser... También se consideran vulnerables.

Los métodos pueden incluir las siguientes actividades:

- entrevistar a personas y usuarios;
- cuestionarios;
- inspección física;
- análisis de documentos.

A.2.5.4 Escenarios operativos

En un enfoque basado en activos, se pueden construir escenarios operativos analizando los diferentes caminos, dentro de los activos de soporte, que las fuentes de riesgo pueden utilizar para llegar a los activos del negocio y su DES.

Analizar esos escenarios puede ayudar a profundizar en el enfoque basado en eventos.

Un ataque exitoso suele ser el resultado de la explotación de varias vulnerabilidades. Los ataques intencionales suelen seguir un enfoque secuencial. Este último aprovecha de forma coordinada diversas vulnerabilidades de naturaleza informática, organizativa o física. Este enfoque, basado en la explotación simultánea de vulnerabilidades independientes, puede tener graves consecuencias, aunque las vulnerabilidades explotadas sean insignificantes si se consideran individualmente.

Los escenarios analizados pueden estructurarse según una secuencia de ataque típica. Existen varios modelos que pueden utilizarse (p. ej., el modelo de cadena de ataque cibernético¹). Este enfoque debería permitir identificar los activos de apoyo críticos que pueden utilizarse como vectores de entrada o explotación, o como punto de propagación del ataque modelado.

Estos escenarios pueden representarse en forma de gráficos o diagramas de ataque, útiles para representar los métodos de ataque del atacante.

A.2.6 Ejemplos de escenarios aplicables en ambos enfoques

Los escenarios de riesgo se pueden construir utilizando un enfoque basado en eventos, un enfoque basado en activos o ambos.

[La figura A.4](#) muestra la evaluación de riesgos basada en escenarios de riesgo.

¹) El modelo de cadena de destrucción cibernética es el nombre comercial de un producto suministrado por Lockheed Martin. Esta información se proporciona para comodidad de los usuarios de este documento y no constituye una aprobación por parte de ISO del producto mencionado. Se podrán utilizar productos equivalentes si se demuestra que producen los mismos resultados.

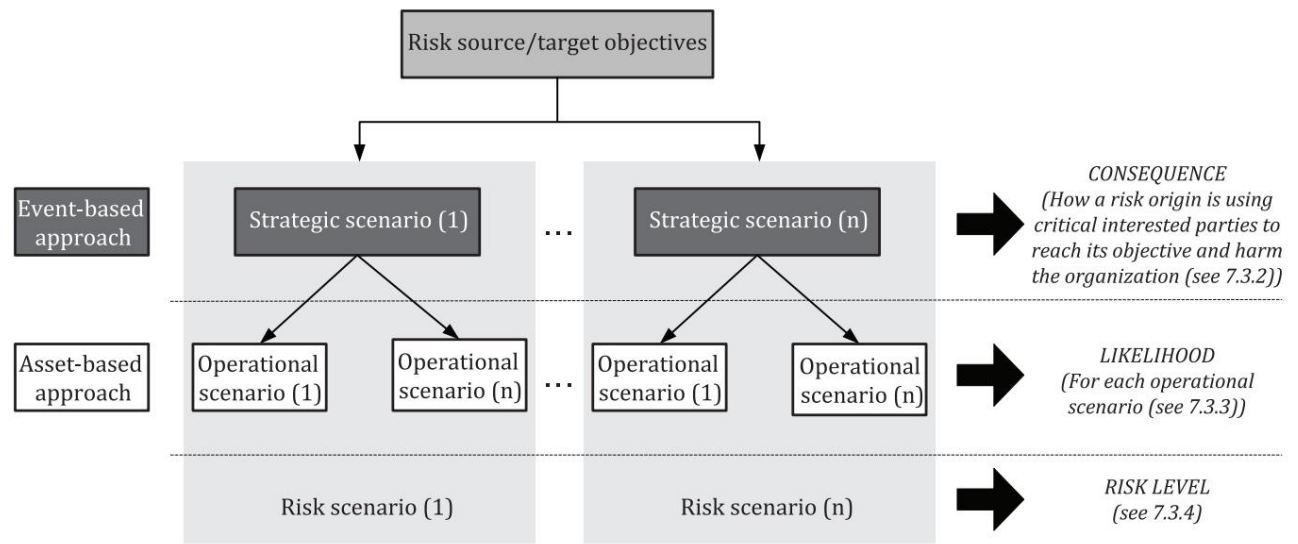


Figura A.4 — Evaluación de riesgos basada en escenarios de riesgo

En el cuadro A.12 se muestran ejemplos de escenarios de riesgo y sus vínculos con los enfoques basados en activos/eventos y las fuentes de riesgo.

Cuadro A.12 — Ejemplos de escenarios de riesgo en ambos enfoques

Fuente de riesgo	Objetivo objetivo	Escenario de riesgo estratégico	Escenario de riesgo operacional
	DES	(Enfoque basado en eventos)	(Enfoque basado en activos)
Autoritario estado	Adquirir una perspectiva estratégica	Subvirtiendo infraestructura crítica	Desplegando vectores de ataque ocultos y persistentes malware en la cadena de suministro
Crimen organizado	Desarrollo de actividades ilegales actividades	Explotación de infraestructuras portuarias	Infiltración del sindicato de estibadores
		Fraude del carrusel fiscal	Tomando el control de un sistema computarizado de gestión de flujo
		Extorsión	Creación de empresas fantasma para realizar intercambios falsos en el mercado del impuesto al carbono
Negocios agresivos	Obtener un monopolio de mercado	Influir en el regulador	Distribuyendo ransomware
		Eliminación de competidores	Corromper a un tomador de decisiones
			Campaña de difamación en redes sociales

A.2.7 Monitoreo de eventos relacionados con el riesgo

El monitoreo de eventos relacionados con riesgos es la identificación de factores que pueden influir en un escenario de riesgo de seguridad de la información como se define en 10.5.2.

En este contexto, los factores se identifican como un conjunto de elementos que permiten detectar un comportamiento inesperado hacia un determinado activo y que pueden integrarse en las capacidades y herramientas de monitoreo de la organización para determinar el detonante de un escenario de riesgo de seguridad de la información.

El seguimiento de eventos relacionados con riesgos puede definirse mediante diversos indicadores provenientes de escenarios operativos o estratégicos, ambos presentados en el apartado 7.2.1. Estos pueden ser de diversa naturaleza (técnica, organizativa, de comportamiento, resultados de auditorías, etc.). Los eventos se monitorizan según prioridades definidas, como la magnitud de las consecuencias y la probabilidad de ocurrencia.

La Tabla A.13 proporciona un ejemplo de descripción de un escenario de riesgo de seguridad de la información con sus eventos de monitoreo relacionados con el riesgo.

ISO/IEC 27005:2022(E)

Tabla A.13 — Ejemplo de relación entre el escenario de riesgo y el seguimiento de eventos relacionados con el riesgo

Componentes de riesgo	Ejemplos		Eventos a monitorear
Escenario estratégico (evento basado)	Los documentos sensibles son destruidos por un administrador		
Eventos en cuestión	Pérdida de documentos críticos		
Gravedad de la consecuencia	Medida descriptiva: alta		
Escenarios operativos (basado en activos)	Uso de derechos de administrador para destruir documentos confidenciales accediendo directamente a la base de datos	->	Detección de un acceso directo a la base de datos fuera del horario laboral habitual
	Acceso root para modificar la fecha/hora del sistema		
	Infección de malware de la estación de trabajo del administrador con propagación en la base de datos	->	Detección de operaciones que impactan un gran volumen de datos (Destrucción)
Probabilidad	Medida descriptiva: media		
Fuente de riesgo	Administrador		
Objetivo objetivo	Compromiso de la disponibilidad de documentos sensibles		
DES	Compromiso del sistema		
Controles de seguridad	Implementación de la estrategia de respaldo		
	Solución antimalware		
	Implementación de NTP		
	Fortalecimiento del sistema operativo		
	Restricción de los derechos de acceso a los datos operativos		

El modelo origen-función-destino-disparador (SFDT) permite construir eventos de monitoreo relacionados con riesgos, donde:

- fuente: indica de dónde proviene el evento/técnica (¿quién y por qué?) y se puede asociar a los recursos A.2.3 ;
- función: indica el tipo de evento/técnica realizada por el atacante (¿qué?);
- destino: indica sobre qué se realiza la técnica o evento (sobre qué soporte primario ¿activos?);
- disparador: indica qué condiciones permiten detectar e identificar el escenario de riesgo (resultados de la ataque).

En la Figura A.5 se presenta un ejemplo de la aplicación del modelo SFDT.

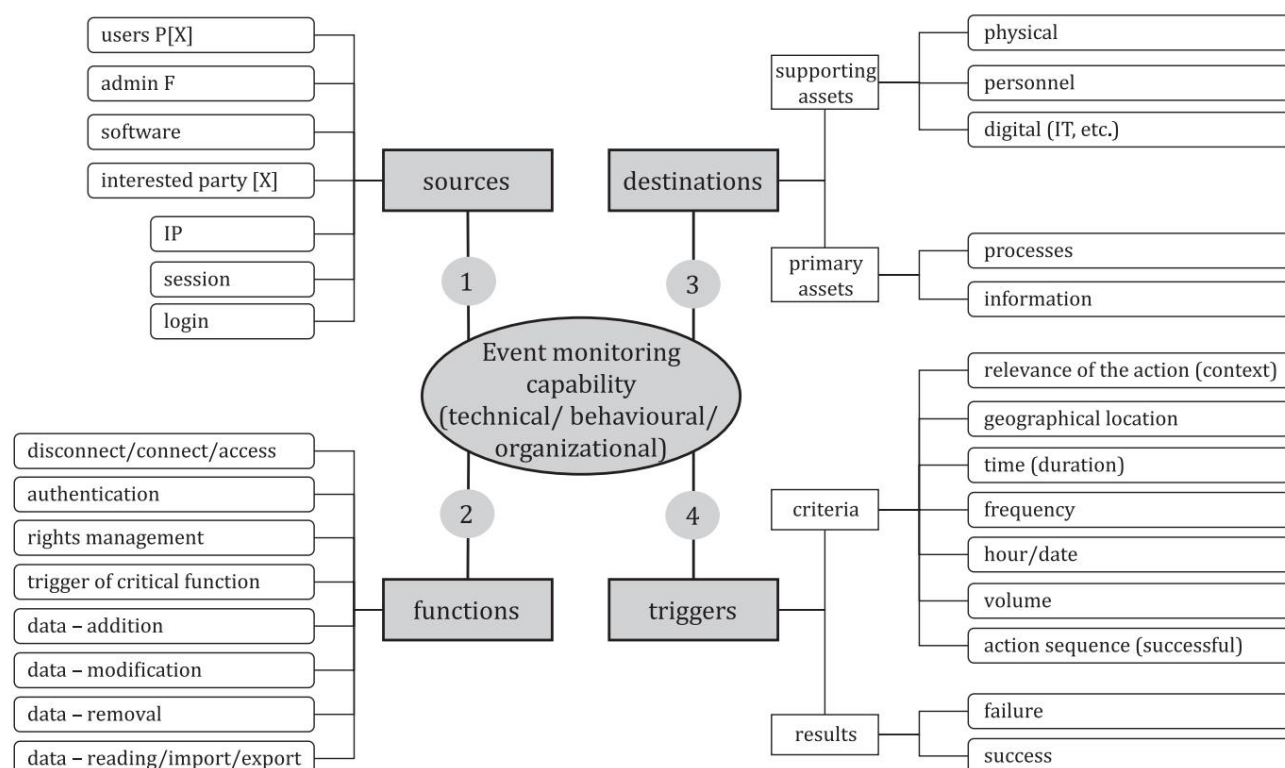


Figura A.5 — Ejemplo de aplicación del modelo SFDT

Para garantizar que un evento de monitoreo de riesgos sea efectivo y eficiente para monitorear un escenario de riesgo de seguridad de la información, es necesario determinar sus indicadores.

Los indicadores de seguimiento de eventos relacionados con el riesgo son:

- el nivel de riesgo del escenario de riesgo que se está monitoreando;
- eficacia, capacidad de los eventos relacionados con el riesgo para monitorear un escenario de riesgo;
- eficiencia, relación entre alertas positivas verdaderas y falsas positivas, o el coste de la caracterización.

Bibliografía

- [1] ISO 17666:2016, Sistemas espaciales — Gestión de riesgos
- [2] ISO/IEC 27001:2022, Tecnología de la información — Técnicas de seguridad — Sistemas de gestión de la seguridad de la información — Requisitos
- [3] ISO/IEC 27003, Tecnología de la información — Técnicas de seguridad — Sistemas de gestión de la seguridad de la información — Guía
- [4] ISO/IEC 27004, Tecnología de la información — Técnicas de seguridad — Gestión de la seguridad de la información — Seguimiento, medición, análisis y evaluación
- [5] ISO/IEC 27014, Seguridad de la información, ciberseguridad y protección de la privacidad — Gobernanza de la seguridad de la información
- [6] ISO/IEC/TR 27016, Tecnología de la información — Técnicas de seguridad — Gestión de la seguridad de la información — Economía organizacional
- [7] ISO/IEC 27017, Tecnología de la información — Técnicas de seguridad — Código de prácticas para controles de seguridad de la información basado en ISO/IEC 27002 para servicios en la nube
- [8] ISO/IEC 27701, Técnicas de seguridad — Extensión a ISO/IEC 27001 e ISO/IEC 27002 para la gestión de la información de privacidad — Requisitos y directrices
- [9] ISO 31000:2018, Gestión de riesgos — Directrices
- [10] IEC 31010:2019, Gestión de riesgos — Técnicas de evaluación de riesgos
- [11] Guía ISO 73:2009, Gestión de riesgos — Vocabulario

ISO/IEC 27005:2022(E)

ICS 35.030

Precio basado en 62 páginas